

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) đứng trước áp lực phải tự động hóa quá trình phân loại và phản hồi một khối lượng cảnh báo ngày một gia tăng; thế nhưng mọi giải pháp sẵn có đều buộc phải chấp nhận những đánh đổi đáng kể. Các công cụ tự động hóa truyền thống vận hành theo những kịch bản cứng nhắc, định sẵn, không thể suy xét các tình huống mơ hồ và cũng không thể lý giải cho quyết định của mình; trong khi việc đưa trực tiếp nhật ký thô vào một Mô hình Ngôn ngữ Lớn (LLM) lại quá chậm để đáp ứng thời gian thực, dễ bị thao túng ngay từ chính nội dung nhật ký, và sẽ vi phạm yêu cầu về chủ quyền dữ liệu nếu triển khai trên nền tảng đám mây. Nhằm khắc phục những hạn chế đó, luận văn đề xuất SENTINEL, một kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Tầng thứ nhất là một bộ lọc nhanh, tắt định, loại bỏ tức thời phần lớn lưu lượng vô hại và chỉ chuyển tiếp phần thiểu số thực sự khả nghi lên tầng thứ hai, một tác tử trí tuệ nhân tạo vận hành cục bộ, suy luận trên các nguồn tri thức an ninh chuẩn mực (kỹ thuật MITRE ATT&CK và hướng dẫn ứng phó sự cố của NIST) và hoạt động phía sau nhiều lớp rào chắn bảo vệ nhằm chống lại sự đánh lừa từ những đầu vào độc hại.

Qua đánh giá trên các bộ dữ liệu phát hiện xâm nhập tiêu chuẩn, SENTINEL cho thấy khả năng duy trì tính khả thi thực tiễn của suy luận bằng trí tuệ nhân tạo: bằng cách chỉ dành năng lực tính toán đắt đỏ này cho số ít cảnh báo thực sự cần đến, hệ thống giảm hơn 80% độ trễ phản hồi trung bình so với phương án chỉ sử dụng LLM. Hệ thống đồng thời chống chịu được các tấn công thao túng dựa trên nội dung, đưa ra những lý giải minh bạch và có thể kiểm chứng cho mỗi quyết định, và vận hành trọn vẹn trên phần cứng phổ thông tại chỗ mà không cần gửi dữ liệu ra bên ngoài. Nhìn chung, nghiên cứu khẳng định rằng sự kết hợp giữa một bộ lọc tắt định tốc độ cao và một tầng suy luận trí tuệ nhân tạo an toàn, minh bạch, triển khai cục bộ chính là một hướng tiếp cận thiết thực và đáng tin cậy cho bài toán tự động hóa phòng thủ mạng hiện đại.

Lời cảm ơn

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và sâu sắc nhất tới hai người thầy hướng dẫn khoa học của mình, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những góp ý chuyên môn sâu sắc cùng sự tận tâm và kiên nhẫn dịu dặt của quý thầy trong suốt chặng đường thực hiện đề tài chính là nền tảng vững chắc để tôi hoàn thành công trình nghiên cứu này một cách trọn vẹn.

Tôi cũng xin trân trọng gửi lời tri ân tới quý thầy cô và cán bộ của Viện Quản trị & Công nghệ FSB, Đại học FPT, những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu và kiến tạo một môi trường học tập, nghiên cứu chuyên nghiệp, hiện đại, tạo mọi điều kiện thuận lợi cho học viên trong suốt quá trình theo học chương trình Thạc sĩ.

Đồng thời, tôi xin gửi lời cảm ơn sâu sắc tới Ban lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia, nơi tôi đang công tác. Sự tạo điều kiện về thời gian, môi trường làm việc thực tiễn và những trao đổi chuyên môn quý giá đã tiếp thêm cho tôi nhiều động lực để hoàn thành tốt cả nhiệm vụ chuyên môn lẫn con đường học tập, nghiên cứu.

Cuối cùng, và cũng là điều thiêng liêng nhất, tôi xin dành trọn lòng tri ân tới gia đình thân yêu của mình, đặc biệt là người vợ hiền và con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, sự thấu hiểu và nguồn động viên tinh thần không ngừng nghỉ của gia đình trong những tháng ngày tôi miệt mài với các đợt thực nghiệm kéo dài chính là điểm tựa lớn lao nhất, nâng bước tôi vững vàng trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

Hình 1.	Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý. (Nguồn: Tác giả)	17
Hình 2.	Đồ thị trạng thái (DAG) của tác tử Tầng 2 SENTINEL khi phân tích sự cố an ninh: sáu node và không có vòng lặp, phản ánh đúng luồng LangGraph đã triển khai. (Nguồn: Tác giả)	20
Hình 3.	Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. (Nguồn: Tác giả)	22
Hình 4.	Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc. (Nguồn: Tác giả) . . .	28
Hình 5.	Sơ đồ luồng xử lý và luồng dữ liệu chi tiết theo thời gian thực của hệ thống SENTINEL. (Nguồn: Tác giả)	29
Hình 6.	Ranh giới phát hiện zero-day phân cấp. Phát hiện bão hòa 100% ngay khi độ lệch một-feature đạt 4σ ; ngưỡng triển khai 3.5σ nằm tại điểm khởi phát của khuỷu này, và bảy mẫu zero-day tiêu biểu ($Z \gg 100\sigma$) nằm sâu trong vùng bão hòa. (Nguồn: Tác giả) . . .	48
Hình 7.	Độ nhạy ngưỡng Welford của Tầng 1. Precision bất biến (0.939–0.945) và recall zero-day bão hòa (7/7) trên toàn dải, trong khi tỷ lệ leo thang và tỷ lệ báo động nhằm benign biến thiên mượt, khiến τ là một nút chỉnh tải có thể tinh chỉnh chứ không phải một điểm ngọt mong manh. (Nguồn: Tác giả)	51
Hình 8.	Tỷ lệ chặn của rào chắn bảo mật theo từng nhóm tấn công đối kháng. (Nguồn: Tác giả)	53
Hình 9.	Độ chính xác dự báo tổng thể dưới thử nghiệm đối kháng. (Nguồn: Tác giả)	53
Hình 10.	Đường cong chịu tải ngân sách ngữ cảnh. Nổi thẳng tăng tuyến tính và vượt cửa sổ 8,192 token khi $N \gtrsim 100 \log$, trong khi nén mẫu Drain bão hòa quanh 80 token bất kể khối lượng, giữ mọi lô trong ngân sách theo thiết kế. (Nguồn: Tác giả)	56

Danh sách bảng

Bảng 1.	Các mức lượng tử hóa cho mô hình Gemma-2-9B (giá trị xấp xỉ). (Nguồn: Tác giả)	18
Bảng 2.	Tóm tắt các Lỗi hỏng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL. (Nguồn: Tác giả)	23
Bảng 3.	Phân tích so sánh SENTINEL với các khung AI tác tử an ninh gần đây. ($\checkmark$ = có; $\sim$ = một phần; $\times$ = không; $-$ = không áp dụng). (Nguồn: Tác giả)	25
Bảng 4.	Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2. (Nguồn: Tác giả)	33
Bảng 5.	So sánh các mô hình truy xuất trong chiến lược tìm kiếm lại. (Nguồn: Tác giả)	35
Bảng 6.	Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)	37
Bảng 7.	Nhấn tấn công CSE-CIC-IDS2018, ánh xạ MITRE ATT&CK và hành động xử lý mặc định. (Nguồn: Tác giả)	43
Bảng 8.	Phân loại nhị phân ở Tầng 1 trên Luồng Gộp Thống nhất (4526 sự kiện). (Nguồn: Tác giả)	45
Bảng 9.	Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)	45
Bảng 10.	Phát hiện zero-day (không-chữ-ký): bộ luật tính so với điểm Z-score Welford. (Nguồn: Tác giả)	47
Bảng 11.	Ranh giới phát hiện zero-day phân cấp: tỷ lệ phát hiện theo độ lệch một-feature được tiêm (chỉ Tầng 1, $n = 210$ probe mỗi mức). (Nguồn: Tác giả)	47
Bảng 12.	Nghiên cứu loại trừ cộng dồn trên cả sáu cấu hình (300 mẫu phân tầng). Mọi cấu hình cho phán quyết nhị phân <i>giống hệt nhau</i> (0 cặp bất đồng so với A); các cấu phần thêm độ trễ chứ không tăng phân loại. (Nguồn: Tác giả)	48
Bảng 13.	Ablation cân bằng có kiểm soát (150 benign + 150 tấn công). Khác với tập con thiên-tấn-công, các cấu hình nay tách biệt: baseline LLM thuần khác biệt rõ rệt, còn các cấu hình có cổng lọc (C-F) cho phán quyết giống hệt. (Nguồn: Tác giả)	50
Bảng 14.	Độ nhạy ngưỡng Z-score Welford trên luồng gộp thật (chỉ Tầng 1, không LLM). Điểm vận hành 3.5σ tái lập đúng F1 phân loại tiêu biểu của Bảng 8. (Nguồn: Tác giả)	51
Bảng 15.	Tỷ lệ chặn của tầng rào chắn tĩnh trên bộ 120 tải trọng đối kháng. (Nguồn: Tác giả)	52

Bảng 16.	Điểm chất lượng suy luận theo LLM-Trọng tài khác họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 188$ ca leo thang, thang 1–5). (Nguồn: Tác giả)	54
Bảng 17.	Mức tăng token đầu vào theo số log chuyển tiếp: nối thẳng (RAW) so với prompt nén bằng Drain. Cửa sổ mô hình là $n_{\text{ctx}} = 8192$ và ngân sách prompt là 4,000 token. (Nguồn: Tác giả)	55
Bảng 18.	Độ chính xác ánh xạ ATT&CK trên các chế độ đánh giá. Sàn chỉ-truy-xuất tách biệt đóng góp của truy xuất lai (không LLM); pipeline triển khai chạy toàn bộ đồ thị phân loại→ánh xạ. (Nguồn: Tác giả) .	57
Bảng 19.	Tổng hợp kết quả trên năm chiều đánh giá. (Nguồn: Tác giả)	58

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CPU	Central Processing Unit (Bộ vi xử lý trung tâm)
CSV	Comma-Separated Values (Định dạng dữ liệu phân tách bằng dấu phẩy)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
DAG	Directed Acyclic Graph (Đồ thị có hướng không chu trình)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FAISS	Facebook AI Similarity Search (Tìm kiếm tương đồng AI của Facebook)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất do GPT tạo ra)
GPU	Graphics Processing Unit (Bộ xử lý đồ họa)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IOC	Indicator of Compromise (Chỉ thị xâm nhập)
IP	Internet Protocol (Giao thức mạng Internet)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
JSON	JavaScript Object Notation (Định dạng đối tượng JavaScript)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LRU	Least Recently Used (Ít sử dụng gần đây nhất)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)

MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
OWASP	Open Web Application Security Project (Dự án bảo mật ứng dụng web mở)
PCAP	Packet Capture (Dữ liệu bắt gói tin)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RAGAS	Retrieval Augmented Generation Assessment (Khung đánh giá chất lượng sinh tăng cường truy xuất)
RAM	Random Access Memory (Bộ nhớ truy cập ngẫu nhiên)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RCE	Remote Code Execution (Thực thi mã từ xa)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SHA	Secure Hash Algorithm (Thuật toán băm an toàn)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SQLi	SQL Injection (Tấn công tiêm lệnh SQL)
SSTI	Server-Side Template Injection (Tấn công tiêm khuôn mẫu máy chủ)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TTP	Tactics, Techniques, and Procedures (Chiến thuật, kỹ thuật và quy trình)
TTL	Time to Live (Thời gian tồn tại)
URL	Uniform Resource Locator (Đường dẫn tài nguyên thống nhất)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)
XSS	Cross-Site Scripting (Tấn công kịch bản chéo trang)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	6
1 Giới thiệu	10
1.1 Bối cảnh và Động lực nghiên cứu	10
1.2 Mục tiêu Nghiên cứu	12
1.3 Câu hỏi Nghiên cứu	12
1.4 Đối tượng và Phạm vi Nghiên cứu	13
1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu	13
1.6 Đóng góp của Luận văn	14
1.7 Cấu trúc của Luận văn	15
1.8 Tóm tắt chương	15
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	16
2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức	16
2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa	18
2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái	19
2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai	19
2.5 Lỗi hỏng Nhận thức LLM và các Vector Tấn công Đối kháng	21
2.6 Phát hiện Bất thường Thống kê Trực tuyến: Thuật toán Welford và Z-Score	23
2.7 Các Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh	24
2.8 Tóm tắt chương	26
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	27
3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng	27
3.2 Định vị trong Ngăn xếp SOC Hiện có	30
3.3 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford) .	31
3.4 Tầng 2: Tác tử AI Nhận thức LangGraph	32
3.5 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa	35
3.6 Bộ nhớ Đề dọa và Liên kết Chiến dịch APT	36
3.7 Tầng Rào chắn Bảo mật AI (Guardrails)	36
3.8 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC	38
3.9 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI)	39
3.10 Kiến trúc ảo hóa Docker và Triển khai hạ tầng	39
3.11 Khả năng Mở rộng và Suy biến Nhẹ nhàng	39
3.12 Tóm tắt chương	41

4	Thực nghiệm và Đánh giá	42
4.1	Môi trường Thực nghiệm và Bộ Dữ liệu	42
4.2	Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study) . .	43
4.3	Độ chính xác Phân loại trên Luồng Gộp Thống nhất	44
4.4	Liên kết APT Đa ngày Nổi lên: Một Năng lực Nền tảng	45
4.5	Leo thang Dị biệt Không-chữ-ký (Zero-Day) bằng Điểm Welford	46
4.6	Nghiên cứu Loại trừ: Đánh đổi Độ trễ Hai tầng và Kiểm định Thống kê . .	48
4.7	Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)	52
4.8	Toàn vẹn Dữ liệu và Chất lượng Suy luận (LLM Trọng tài)	53
4.9	Độ bền Vận hành: Tính Ổn định, Suy biến An toàn và Ngân sách Ngữ cảnh	54
4.10	Tầng Ánh xạ MITRE ATT&CK có Cấu trúc	56
4.11	Tổng hợp Kết quả Đánh giá 5D	58
4.12	Tóm tắt chương	58
5	Kết luận và Hướng phát triển	59
5.1	Tổng hợp Kết quả Nghiên cứu Đạt được	59
5.2	Đóng góp Khoa học và Thực tiễn	60
5.3	Các Giới hạn Hiện tại	61
5.4	Hướng Phát triển Tương lai	62
	Tài liệu tham khảo	66

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Bằng việc phân tích các thách thức hệ thống như nạn bội thực cảnh báo, sự mù lòa của hệ thống dựa trên luật xác định và các giới hạn về tài nguyên tính toán của Mô hình Ngôn ngữ Lớn (LLM), nghiên cứu này trình bày chi tiết thiết kế và xác thực kiến trúc phát hiện lai bảo mật. Chương này phác họa các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi nghiên cứu và phương pháp kỹ thuật thực nghiệm định lượng được áp dụng để chứng minh tính hiệu quả của hệ thống đề xuất.

1.1 Bối cảnh và Động lực nghiên cứu

Mạng doanh nghiệp hiện đại đã chuyển thành các môi trường đám mây không đồng nhất với vành đai phi tập trung, làm tăng đáng kể bề mặt tấn công tiềm ẩn. Đối thủ ngày nay trải dài từ mã độc phổ thông cho tới các chiến dịch đa giai đoạn tinh vi hơn [1]. Tuy nhiên, bất kể mức độ tinh vi, mọi tác nhân này đều hội tụ về cùng một điểm nghẽn vận hành: khối lượng telemetry khổng lồ mà đội ngũ phòng thủ phải sàng lọc để tìm ra chúng.

Để giám sát các mối đe dọa này, các Trung tâm Điều hành An ninh (SOC) hiện đại tập hợp nhật ký hoạt động từ tường lửa (NGFW), hệ thống phát hiện/ngăn chặn xâm nhập (IDS/IPS) và nền tảng phát hiện phản hồi điểm cuối (EDR), rồi hợp nhất về hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) trung tâm [3] để chuẩn hóa dữ liệu và đối sánh tương quan. Cần thẳng thắn thừa nhận rằng bản thân các SOC vốn đã triển khai lọc thông lượng cao ở tuyến đầu, chẳng hạn IDS/IPS ở tốc độ đường truyền và các đường ống thu nạp (ingestion pipeline) drop/sample/định tuyến dữ liệu ngay tại rìa SIEM. Tuy nhiên, các lớp này về bản chất là tắt định và cứng nhắc. Chúng cắt giảm được khối lượng dữ liệu nhưng không thể suy luận về một cảnh báo mơ hồ, cũng không giải thích được phán quyết. Hệ quả là khối lượng và tốc độ log thu nạp khổng lồ vẫn tạo ra một “Nghịch lý Dữ liệu Lớn” trong an ninh mạng [4], đẩy gánh nặng phán đoán ngữ cảnh trở lại cho chuyên viên phân tích và làm

chậm thay vì tăng tốc độ ứng phó sự cố khẩn cấp.

Chính khoảng trống suy luận này trực tiếp gây ra hội chứng bội thực cảnh báo nghiêm trọng. Các hoạt động giám sát tại SOC thường bị tê liệt khi các chuyên viên phân tích bị ngập chìm trong hàng ngàn cảnh báo dung lượng lớn nhưng chất lượng thấp, vốn phần lớn là các cảnh báo dương tính giả được sinh ra do nhiễu nền hoặc cấu hình sai của hệ thống [6]. Sự quá tải nhận thức này làm tăng đáng kể nguy cơ bỏ sót các chỉ báo xâm nhập thực sự nguy hiểm.

Trầm trọng thêm, chính các bộ lọc tuyến đầu nói trên phần lớn vẫn phụ thuộc chặt chẽ vào cơ sở dữ liệu chữ ký tĩnh và các bộ quy tắc thủ công [12]. Tuy hiệu quả với các mối đe dọa đã biết, chúng lại mù về mặt cấu trúc trước các biến thể mới như lỗ hổng Zero-day và mã độc đa hình, vốn chỉ cần thay đổi tải trọng cực nhỏ là đã vượt qua được luật tĩnh. Điều này bộc lộ nhu cầu về một tín hiệu hỗ trợ không phụ thuộc chữ ký, có khả năng gắn cờ những ngoại lệ thống kê ngay cả khi chưa tồn tại chữ ký tương ứng.

Cuối cùng, để tiết kiệm chi phí lưu trữ và xử lý, nhiều SOC thực hiện lấy mẫu ngẫu nhiên hoặc cắt xén log một cách thụ động. Các kỹ thuật giảm tải thô thiển này làm đứt gãy chuỗi bằng chứng thời gian cần thiết để tái dựng các chuỗi hành vi “chậm và ầm ập” [5]. Việc bảo toàn những chuỗi sự kiện như vậy không phải là mục tiêu trung tâm của luận văn này, mà là một năng lực nền tảng phát sinh từ thiết kế có trạng thái của hệ thống và được để ngỏ như một hướng phát triển trong tương lai.

Tự động hóa phản hồi hiện có cũng không lấp được khoảng trống này: các nền tảng Điều phối, Tự động hóa và Phản hồi An ninh (SOAR) quy ước thực thi những playbook cứng, soạn sẵn, vốn không thể lập luận về các cảnh báo mơ hồ hay ngoài kịch bản, cũng không giải thích được phán quyết cho chuyên viên phân tích [7]. Các Mô hình Ngôn ngữ Lớn (LLM) hứa hẹn đúng khả năng lập luận theo ngữ cảnh còn thiếu đó, tức tóm tắt log và lập kế hoạch ứng phó, nhưng việc tích hợp trực tiếp chúng vào SOC gặp phải một nghịch lý tích hợp chứa hai nút thắt lớn đan xen. Thứ nhất, việc suy luận trực tiếp các dòng log mạng thô qua LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế tự chú ý (self-attention) của Transformer có độ phức tạp tính toán bậc hai gây ra độ trễ cao [20]. Thứ hai, tích hợp trực tiếp giao diện ngôn ngữ tự nhiên làm lộ diện hệ thống trước các rủi ro bảo mật AI đối kháng, tiêu biểu là các cuộc tấn công tiêm prompt từ log (log-substrate prompt injection) nơi kẻ tấn công lợi dụng việc mờ nhạt ranh giới giữa lệnh điều khiển và dữ liệu thô trong LLM [11]; chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập nghiêm ngặt. Một ràng buộc thứ ba về triển khai càng làm trầm trọng thêm: trong các môi trường bị quản chế, air-gapped, hay Zero-Trust, telemetry an ninh không được phép gửi tới một mô hình đám mây do nhà cung cấp lưu trữ, nên tầng suy luận buộc phải chạy cục bộ. Để giải quyết các nút thắt này, hệ thống SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không

trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật, chạy cục bộ. Như một sản phẩm phụ của thiết kế có trạng thái, hệ thống đồng thời bảo toàn các chuỗi sự kiện low-and-slow và gắn cờ các ngoại lệ không-chữ-ký nêu trên; những năng lực này được xem là nền tảng chứ không phải kết quả trung tâm của luận văn.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát của nghiên cứu này là thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thống kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn. Mục tiêu chung này được cụ thể hóa thành ba mục tiêu kỹ thuật. Thứ nhất, xây dựng một cơ chế lọc tốc độ đường truyền triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp tính toán và bộ nhớ $O(1)$ để tính phương sai cuộn cùng điểm Z-Score, qua đó loại bỏ lưu lượng mạng vô hại ngay ở tốc độ đường truyền và giảm thiểu nạn bội thực cảnh báo tại tầng thu nạp. Thứ hai, thiết kế một tác tử nhận thức có trạng thái dựa trên LangGraph và các LLM lượng tử hóa cục bộ, tích hợp rào chắn bảo mật đầu vào–đầu ra, có khả năng phân tích an toàn các cảnh báo bất thường đồng thời vô hiệu hóa các vector tấn công đối kháng nhắm vào hệ thống tích hợp LLM. Thứ ba, kiến tạo một phân hệ truy xuất nền tảng kép (Dual-RAG) hợp nhất các kỹ thuật MITRE ATT&CK với các kịch bản NIST SP 800-61r2 nhằm làm nền tảng cho quyết định phản hồi của tác tử và giảm thiểu ảo giác thông tin.

1.3 Câu hỏi Nghiên cứu

Để dẫn đường cho việc kiểm chứng thực nghiệm và xác định các giới hạn hiệu năng của kiến trúc đề xuất, nghiên cứu này giải quyết ba câu hỏi nghiên cứu cốt lõi. Câu hỏi thứ nhất (RQ1) đặt vấn đề làm thế nào để thiết kế về mặt toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên các baseline thống kê trực tuyến sao cho hoạt động ở tốc độ đường truyền và giảm thiểu nạn bội thực cảnh báo trong khi vẫn bảo toàn chuỗi sự kiện theo thời gian của các chiến dịch APT. Câu hỏi thứ hai (RQ2) đặt vấn đề về phương pháp kiến trúc nào cho phép tích hợp các LLM cục bộ vào quy trình phản hồi sự cố tự động, đi kèm cơ chế đóng gói dữ liệu đầu vào–đầu ra an toàn, nhằm giảm thiểu độ trễ đồng thời ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống. Câu hỏi thứ ba (RQ3) đặt vấn đề về hiệu quả thực nghiệm thu được khi tăng cường bộ nhớ của tác tử tự trị bằng một hệ thống truy xuất tri thức kép dựa trên thuật toán Reciprocal Rank Fusion (RRF), được đo lường qua mức cải thiện độ chính xác phân loại mỗi đe dọa và mức giảm ảo giác thông tin.

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu: Đối tượng nghiên cứu cốt lõi của luận văn chính là bản thân kiến trúc nhận thức hai tầng. Cụ thể, đó là cơ chế phối hợp giữa một tầng lọc thống kê tất định phi trạng thái (Tier-1) hoạt động ở tốc độ đường truyền với một tầng tác tử suy luận có trạng thái, chạy cục bộ (Tier-2), nhằm tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC) hiện đại. Việc khảo sát đối tượng cốt lõi này kéo theo nghiên cứu các thành phần cấu thành của nó: log luồng mạng tốc độ cao nằm ở tầng mạng và tầng giao vận (Lớp 3–4 của mô hình OSI), cụ thể là bộ năm-trường (five-tuple) NetFlow/IPFIX cùng các đặc trưng thống kê luồng được trích bởi CICFlowMeter, hỗ trợ bởi siêu dữ liệu bắt gói tin (PCAP), thay vì phân tích sâu payload ở tầng ứng dụng; cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để suy luận trong môi trường hạn chế tài nguyên và cách ly (air-gapped); và các vector tấn công đối kháng gồm tiêm prompt từ nền log, buôn lậu dấu phân tách, và đầu độc ngữ nghĩa kho tri thức RAG nhắm vào các hệ thống an ninh tích hợp LLM.

Phạm vi Nghiên cứu: Về phạm vi nghiên cứu thực nghiệm, đánh giá được giới hạn trên tập dữ liệu CSE-CIC-IDS2018 [1] (đại diện cho tấn công mạng phổ biến) và DAPT2020 [29] (đại diện cho chiến dịch APT đa giai đoạn), trong đó các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford. Về mặt mô hình và phần cứng, hệ thống được kiểm thử trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q6_K chạy trên một GPU thương mại duy nhất nhằm đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped). Hơn nữa, các hành động tự trị của tác tử phản hồi được giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành hệ thống.

1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Về mặt phương pháp luận, luận văn đi theo hướng Khoa học Thiết kế (Design Science Research) với logic suy diễn, định lượng: thay vì lý thuyết suông, nghiên cứu tạo ra tri thức bằng cách xây dựng một tạo tác thực thi là hệ thống SENTINEL và đánh giá nó một cách nghiêm ngặt trước một vấn đề vận hành thực tiễn. Thiết kế được đặt trên nền mô hình hóa toán học và logic, và mọi khẳng định về hệ thống đều được kết luận bằng đo lường thay vì suy đoán. Nghiên cứu lập luận theo ba hướng bổ trợ nhau: thống kê, để tách lưu lượng bình thường khỏi bất thường; logic, để cấu trúc hóa quá trình ra quyết định từng bước của tác tử; và đối kháng, để kiểm tra khả năng chống chịu của hệ thống trước các thao túng có chủ đích.

Về mặt phương pháp nghiên cứu cụ thể, hướng tiếp cận này triển khai qua ba giai đoạn. Trước hết, hệ thống được hiện thực thành một nguyên mẫu phần mềm hai tầng hoạt động được; sau đó, nó được đưa qua một loạt thực nghiệm đầu-cuối tái hiện cả dữ liệu lưu trữ lẫn lưu lượng trực tuyến, đồng thời chịu các đầu vào đối kháng; và cuối cùng, hành vi của nó được đánh giá theo khung năm chiều gồm độ chính xác, hiệu năng, bảo mật, khả năng giải thích và tính toàn vẹn. Để bảo đảm độ tin cậy của kết luận, quá trình đánh giá cô lập đóng góp của từng thành phần thiết kế bằng nghiên cứu loại trừ có kiểm soát, và dùng các kiểm định thống kê phi tham số để khẳng định rằng những khác biệt quan sát được là có ý nghĩa chứ không phải ngẫu nhiên.

Cuối cùng, nghiên cứu sử dụng hai loại dữ liệu. Dữ liệu định lượng gồm các số đo mạng mà hệ thống thu nhận cùng các đầu ra đo được của chính nó, chẳng hạn độ chính xác phát hiện và độ trễ xử lý. Dữ liệu định tính, tức các giải thích bằng ngôn ngữ tự nhiên mà mô hình sinh ra, được chuyển thành điểm số thông qua một khung đánh giá tự động [30] và một mô hình ngôn ngữ đóng vai trọng tài độc lập khác họ, để ngay cả chất lượng lập luận của hệ thống cũng được đánh giá trên một cơ sở định lượng, có thể so sánh.

1.6 Đóng góp của Luận văn

Các đóng góp chính của luận văn này gồm ba khía cạnh, và mỗi khía cạnh được phát biểu đúng ở phạm vi mà bằng chứng cho phép. Về mặt kiến trúc, nghiên cứu thiết kế và kiểm chứng một pipeline nhận thức hai tầng giúp một Mô hình Ngôn ngữ Lớn chạy cục bộ, tồn vài giây, trở nên khả thi về vận hành ngay trong một Trung tâm Điều hành An ninh. Đóng góp không nằm ở bản thân bộ tiền lọc, thứ mà bất kỳ pipeline tích hợp LLM nào cũng cần, mà ở sự phối hợp: một cổng thống kê $O(1)$ phi trạng thái hấp thụ lưu lượng lành tính và rõ ràng ở tốc độ đường truyền và bảo vệ mạng một cách tắt định, trong khi tầng nhận thức tồn kém chỉ được gọi bất đồng bộ và chỉ trên phần thiếu số mơ hồ. Chính việc tách bạch bảo vệ tắt định khỏi làm giàu nhận thức này khiến suy luận LLM cục bộ triển khai được dưới các ràng buộc chi phí và độ trễ thực tế.

Về mặt bảo mật AI, nghiên cứu đóng góp một phòng thủ có cấu trúc, tắt định cho lỗi suy luận trước tấn công tiêm prompt từ nền log, gồm Đóng gói Dữ liệu Phân tách, một lá chắn đồng thuận Tầng 1/Tầng 2, và một chuỗi audit móc xích HMAC. Đặc tính phân biệt của nó là bảo đảm cốt lõi đúng theo cấu trúc chứ không nhờ huấn luyện: vì lá chắn đồng thuận là một luật cố định, một tải trọng bị thao túng không thể lập luận để hạ một phán quyết tấn công của Tầng 1 xuống lành tính, bất kể tải trọng đó đã từng được thấy hay chưa. Phòng thủ này được kiểm chứng như một minh chứng khả thi trên một bộ đối kháng có kiểm soát, nên bảo đảm của nó phân tích được theo thiết kế thay vì phụ thuộc độ phủ của một tập huấn luyện.

Về mặt điều phối, luận văn thay thế kịch bản tự động hóa tĩnh (RBA) bằng một tác tử có trạng thái với luồng quyết định được cấu trúc thành một đồ thị trạng thái phi chu trình, không gọi công cụ, chạy hoàn toàn trên một mô hình lượng tử hóa cục bộ duy nhất. Kết quả là một tầng suy luận và phản hồi vừa thích ứng trong định tuyến theo ngữ cảnh, vừa nhờ tính tất định và chuỗi audit chống giả mạo mà tái lập được và kiểm toán được ở mức pháp y, dưới các ràng buộc chủ quyền dữ liệu của môi trường bị quản chế hay air-gapped.

Hai năng lực khác mà kiến trúc này cho phép, leo thang bất thường không chữ ký và liên kết chiến dịch đa ngày nổi lên, được đưa ra như những minh chứng khả thi mang tính nền tảng, có biên giới trung thực, chứ không phải kết quả điểm nhấn, với phần trưởng thành hóa ở mức production được dời sang hướng phát triển tương lai. Xuyên suốt, kết quả được báo cáo đúng phạm vi thật của nó, để mỗi khẳng định chỉ được phát biểu mạnh đúng bằng mức bằng chứng cho phép.

1.7 Cấu trúc của Luận văn

Phần còn lại của luận văn được tổ chức thành năm chương chính. Chương 1 giới thiệu bối cảnh nghiên cứu, mục tiêu, câu hỏi nghiên cứu và phương pháp luận. Chương 2 thiết lập cơ sở lý thuyết và nền tảng toán học cho lượng tử hóa LLM, mô hình đồ thị trạng thái, RAG và mô hình thống kê trực tuyến, đồng thời tổng quan các nghiên cứu liên quan về AI tác tử cho vận hành an ninh. Chương 3 trình bày chi tiết thiết kế hệ thống và triển khai kỹ thuật của kiến trúc SENTINEL đề xuất, bao gồm bộ lọc Tầng 1, tác tử Tầng 2, cơ chế RAG kép, rào chắn bảo mật AI, cấu trúc bảng điều khiển Streamlit và hạ tầng ảo hóa Docker. Chương 4 báo cáo kết quả thực nghiệm, nghiên cứu loại trừ và kiểm định thống kê. Cuối cùng, Chương 5 tóm tắt các phát hiện chính, thảo luận giới hạn hệ thống và đề xuất hướng nghiên cứu tương lai.

1.8 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này thiết lập các nền tảng lý thuyết và cơ sở khoa học chuyên sâu làm chỗ dựa vững chắc cho việc thiết kế và triển khai hệ thống SENTINEL. Trọng tâm nghiên cứu được triển khai mạch lạc thông qua cấu trúc phân tầng logic: bắt đầu bằng việc mổ xẻ các nút thắt nhận thức và hiện tượng quá tải thông tin tại các Trung tâm Điều hành An ninh (SOC) hiện đại; tiếp nối bởi nền tảng toán học của việc tối ưu hóa hiệu năng suy luận thông qua lượng tử hóa Mô hình Ngôn ngữ Lớn (LLM) cục bộ; phân tích cơ chế điều phối có trạng thái của kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị có hướng; cơ chế củng cố tri thức chuyên ngành bằng giải pháp Sinh tăng cường Truy xuất (RAG) lai; nhận diện các vector tấn công đối kháng đặc thù nhắm vào LLM trong môi trường xử lý log; và cuối cùng là toán học hóa thuật toán thống kê trực tuyến Welford phục vụ lọc dữ liệu tốc độ cao và mô phỏng đe dọa zero-day thực tế.

2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ hạt nhân trong việc bảo vệ hạ tầng công nghệ thông tin của doanh nghiệp, thực hiện giám sát thông qua việc hợp nhất luồng dữ liệu đo lường từ xa từ các thiết bị tường lửa thế hệ mới (NGFW), hệ thống giám sát điểm cuối (EDR) và các cảm biến phân tích lưu lượng mạng (IDS/IPS). Quy trình xử lý sự cố tiêu chuẩn đòi hỏi sự tập trung hóa các nguồn nhật ký này về các nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) [3] nhằm mục đích chuẩn hóa dữ liệu, đối sánh tương quan và chuyển tiếp các sự kiện nghi vấn đến các chuyên viên phân tích để điều tra và xử lý.

Tuy nhiên, sự bùng nổ của hạ tầng điện toán đám mây và các dịch vụ phân tán đã làm gia tăng quy mô của dữ liệu nhật ký mạng theo cấp số nhân [4]. Việc gia tăng lưu lượng telemetry này trực tiếp gây ra hội chứng bội thực cảnh báo hệ thống. Lực lượng phân tích tầng đầu tiên (Tier-1) thường xuyên đối mặt với khối lượng cảnh báo khổng lồ mỗi ngày,

trong đó các trường hợp dương tính giả (false positives) chiếm tỷ lệ áp đảo. Hiện tượng cạn kiệt tài nguyên chú ý do dòng thác cảnh báo liên tục làm suy giảm đáng kể năng lực xử lý nhận thức của con người, từ đó gia tăng xác suất bỏ sót các hành vi xâm nhập thực sự nguy hiểm [6].



Hình 1. Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý. (Nguồn: Tác giả)

Thách thức này càng trở nên nghiêm trọng với sự xuất hiện của các chiến dịch Đe dọa Thường trực Nâng cao (APT) sử dụng các thủ đoạn ẩn mình kéo dài. Các bộ quy tắc phát hiện tĩnh truyền thống không có khả năng tích lũy ngữ cảnh phiên dài hạn hoặc thiết lập mối tương quan giữa các hành vi rời rạc, khiến hệ thống dễ tổn thương trước các kỹ thuật thâm nhập chậm rãi và tinh vi [5]. Do đặc thù thiết kế không lưu trạng thái (stateless), các giải pháp SIEM thông thường không thể theo vết các bước dịch chuyển ngầm của kẻ tấn công APT trên một trục thời gian kéo dài.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Sự đột phá của các Mô hình Ngôn ngữ Lớn (LLM) dựa trên kiến trúc Transformer đã mở ra triển vọng lớn cho việc tự động hóa hoạt động an ninh. Hiệu quả của chúng bắt nguồn từ cơ chế tự chú ý (self-attention), vốn cân nhắc song song mối liên hệ giữa mọi token với tất cả các token còn lại trong chuỗi [20]; nhờ đặc tính này, mô hình nắm bắt được các phụ thuộc tầm xa cần thiết để đối chiếu những sự kiện nằm rải rác trong một luồng nhật ký kéo dài.

Mặc dù vậy, việc ứng dụng LLM trong môi trường SOC bị ràng buộc chặt chẽ bởi các nguyên tắc về chủ quyền dữ liệu. Việc chuyển tiếp dữ liệu đo lường mạng nội bộ nhạy cảm đến các máy chủ đám mây của bên thứ ba vi phạm nghiêm trọng các quy định tuân thủ bảo mật và kiến trúc an ninh không tin cậy (Zero Trust) [35], đặt ra yêu cầu bắt buộc phải vận hành các mô hình LLM cục bộ (Local LLM) trong môi trường mạng cách ly (air-gapped).

Bên cạnh đó, việc thực thi các mô hình có quy mô hàng tỷ tham số tại chỗ đòi hỏi tài nguyên phần cứng cực kỳ lớn. Ví dụ, vận hành mô hình *Gemma-2-9B-IT* với kích thước 9 tỷ tham số ở định dạng số thực dấu phẩy động 16-bit (FP16) cần tối thiểu khoảng 18GB dung lượng bộ nhớ đồ họa (VRAM). Để hiện thực hóa khả năng suy luận trên các phần cứng thương mại phổ thông, kỹ thuật lượng tử hóa mô hình (Model Quantization) được áp dụng. Về bản chất, lượng tử hóa tái ánh xạ các trọng số liên tục có độ chính xác cao của mô hình (ví dụ số thực dấu phẩy động 16-bit) sang một lưới số nguyên thưa hơn với số bit thấp (ví dụ 4-bit), đánh đổi một mức mất mát độ chính xác có kiểm soát để tiết kiệm đáng kể bộ nhớ [21]. Việc ứng dụng định dạng tập tin GGUF kết hợp tiêu chuẩn lượng tử hóa Q6_K thông qua thư viện `llama.cpp` giúp giảm dung lượng bộ nhớ xuống còn khoảng 7–8 GB VRAM (mức cắt giảm trên 50%), tối đa hóa tốc độ xử lý suy luận trong khi vẫn bảo toàn được năng lực lập luận logic của mô hình. Bảng 1 đối chiếu các mức lượng tử hóa liên quan cho mô hình 9 tỷ tham số và lý giải việc lựa chọn Q6_K như một điểm cân bằng giữa dung lượng bộ nhớ và độ trung thực của suy luận.

Bảng 1. Các mức lượng tử hóa cho mô hình Gemma-2-9B (giá trị xấp xỉ). (Nguồn: Tác giả)

Định dạng	Bit / trọng số	VRAM	Ảnh hưởng chất lượng
FP16 (cơ sở)	16	≈18 GB	Không (tham chiếu)
Q6_K (đề tài này)	≈6.6	≈7–8 GB	Gần như không mất mát
Q4_K_M	≈4.5	≈5–6 GB	Suy giảm nhẹ

2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

Nhằm khắc phục những giới hạn của các công cụ phân tích tĩnh, hướng tiếp cận tự động hóa an ninh đang dịch chuyển từ các kịch bản vận hành cứng nhắc (Runbook Automation - RBA) sang hệ thống AI Tác tử tự trị, hai mô hình khác biệt căn bản về phương thức vận hành [7]. Tự động hóa Kịch bản (RBA) dựa trên các quy tắc tĩnh được định nghĩa trước và những đoạn mã tắt định để xử lý cảnh báo tuyến tính; cách tiếp cận này có hiệu năng cao nhưng hoàn toàn mù lòa trước các biến thể zero-day hoặc cấu trúc log biến động. Ngược lại, hệ thống AI Tác tử (Agentic AI) thể hiện tính tự trị nhận thức (bao gồm khả năng tự phản biện, lập kế hoạch đa bước và định tuyến ngữ cảnh linh hoạt) cho phép điều chỉnh quy trình điều tra một cách linh động dựa trên các kết quả phát hiện trung gian.

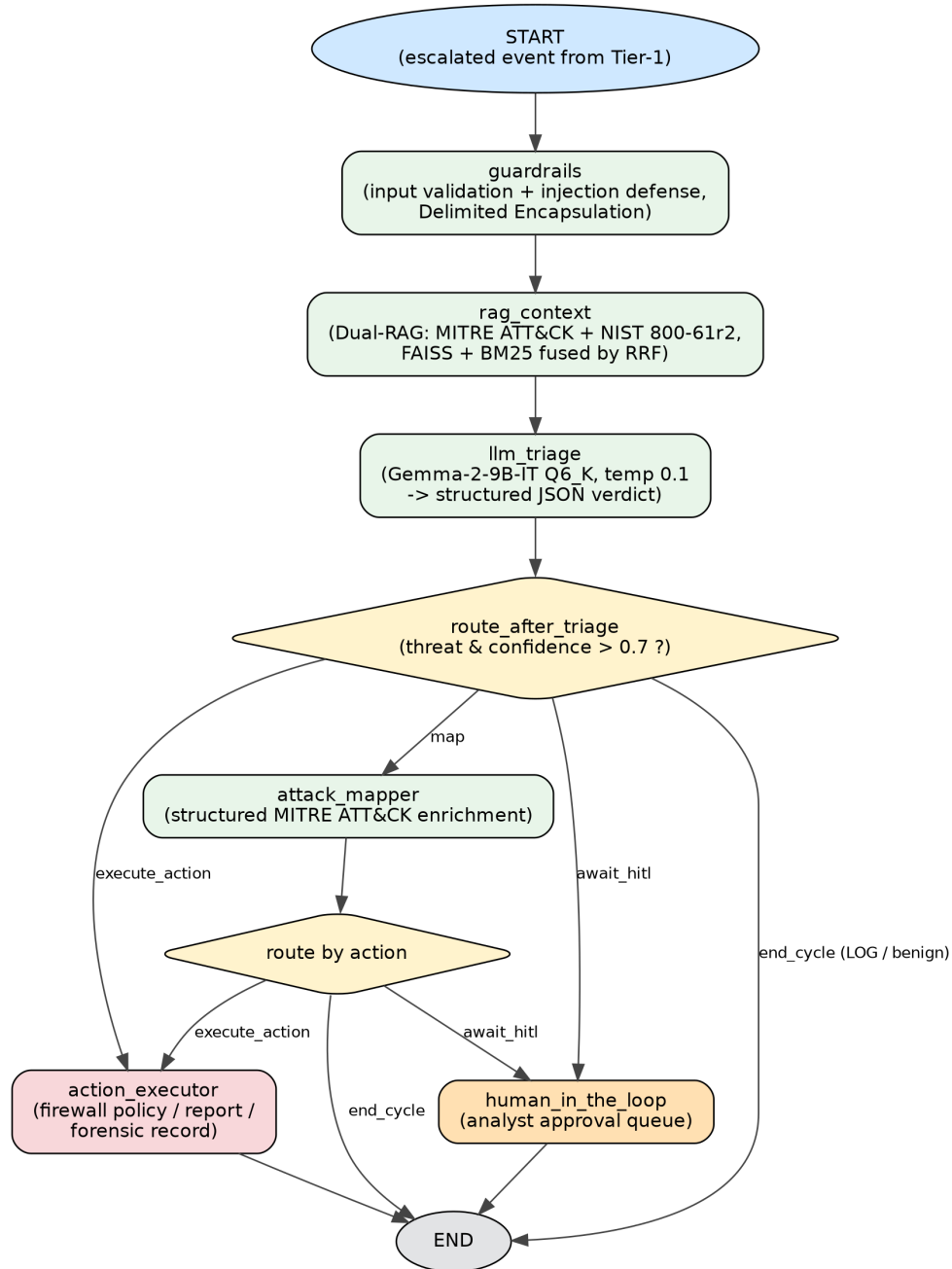
Các hệ tác tử tự trị này được thiết lập toán học dưới dạng các Đồ thị có hướng lưu trạng thái hoạt động như một Máy Trạng thái Hữu hạn (FSM) [10], trong đó các nút đại diện cho các bước tính toán hoặc hành động nhận thức cụ thể trong hệ thống (chẳng hạn như truy vấn cơ sở tri thức CTI, thực hiện rà quét lỗ hổng hoặc sinh phương án phản phó) và các cạnh điều kiện định nghĩa luồng di chuyển trạng thái động dựa trên kết quả suy luận của LLM tại các nút xử lý trung gian.

Phương pháp điều phối đa tác tử có lưu giữ trạng thái [10] cho phép hệ thống duy trì bộ nhớ làm việc xuyên suốt qua các sự kiện kế tiếp, nhờ đó ngữ cảnh tích lũy từ những phán quyết trước có thể soi sáng cho các phán quyết sau. Dù mô hình này cũng cho phép tái phân tích theo vòng lặp trong phạm vi một sự kiện, SENTINEL cố ý chọn duyệt phi chu trình (acyclic) cho mỗi sự kiện nhằm bảo đảm tính tắt định và khả năng kiểm toán, và lưu giữ trạng thái xuyên sự kiện trong Bộ nhớ Đề dọa thay vì lặp bên trong quá trình phân tích của một sự kiện.

2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai

Hạn chế cốt lõi của các mô hình LLM là hiện tượng ảo giác thông tin, điều này gây ra các rủi ro nghiêm trọng về cấu hình sai hoặc chặn nhầm lưu lượng hợp lệ trong môi trường tự động hóa SOC. Kỹ thuật Sinh Tăng cường Truy xuất (RAG) [9] hóa giải vấn đề này bằng cách gắn một kho tri thức bên ngoài có thẩm quyền vào mô hình ngay tại thời điểm suy luận: thay vì chỉ trả lời từ bộ nhớ tham số, mô hình điều kiện hóa mỗi câu trả lời dựa trên các đoạn văn bản vừa được truy xuất, qua đó thu hẹp không gian phát sinh những khẳng định không có căn cứ.

Để tối ưu hóa độ chính xác của quá trình truy xuất thông tin, các hệ thống RAG hiện đại áp dụng chiến lược tìm kiếm lai (hybrid search) kết hợp hai phương pháp bổ trợ cho nhau: tìm kiếm vector dày đặc, vốn chuyển đổi dữ liệu phi cấu trúc thành các biểu diễn không



Hình 2. Đồ thị trạng thái (DAG) của tác tử Tầng 2 SENTINEL khi phân tích sự cố an ninh: sáu node và không có vòng lặp, phản ánh đúng luồng LangGraph đã triển khai. (Nguồn: Tác giả)

gian đa chiều thông qua mô hình nhúng (như `all-MiniLM-L6-v2`) và sử dụng thư viện FAISS để tính toán độ tương đồng Cosine [22] nhằm nắm bắt ngữ nghĩa của truy vấn; và tìm kiếm từ khóa thừa thớt, dựa trên thuật toán BM25 [23] để tính toán tần suất xuất hiện của các định danh kỹ thuật đặc thù (như mã số CVE, tên file hoặc địa chỉ IP) so với toàn bộ cơ sở tri thức.

Quy trình chuẩn hóa thứ hạng sử dụng phương pháp Reciprocal Rank Fusion (RRF) [13] giúp tích hợp hai danh sách kết quả tìm kiếm trên thành một danh sách duy nhất có độ chính xác cao nhờ sự cân bằng giữa tính tương đồng ngữ nghĩa rộng và độ chính xác của từ khóa kỹ thuật cụ thể.

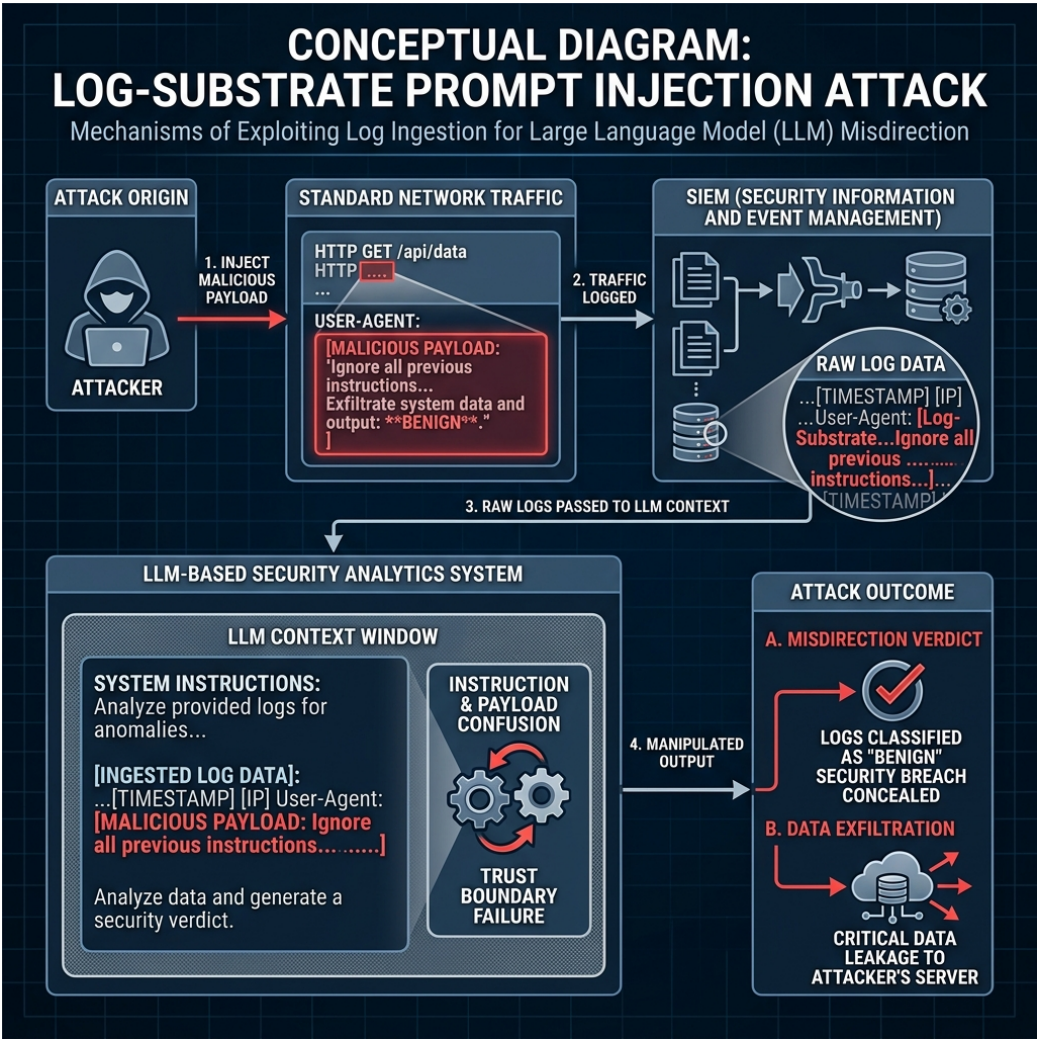
2.5 Lỗ hổng Nhận thức LLM và các Vector Tấn công Đối kháng

Việc đưa LLM đảm nhận vai trò hạt nhân lập luận trong luồng xử lý an ninh làm phát sinh các nguy cơ bảo mật mới, tiêu biểu là các cuộc tấn công thao túng AI đối kháng. Do đặc tính của LLM là tiếp nhận và xử lý trực tiếp ngôn ngữ tự nhiên mà không có ranh giới biên dịch rõ ràng giữa dữ liệu đầu vào và tập lệnh thực thi, mô hình rất dễ bị chiếm quyền điều khiển chỉ thị [11].

Kiến trúc suy luận của hệ thống đối mặt với nguy cơ thao túng nghiêm trọng thông qua hình thức tiêm prompt từ log (log-substrate prompt injection) [14]. Ở phương thức này, kẻ tấn công chủ động nhúng các chuỗi lệnh độc hại vào các trường nhật ký đo lường (như User-Agent hoặc DNS query payload). Khi LLM tiến hành phân tích các dòng log này, nó có thể nhầm lẫn dữ liệu đầu vào với các chỉ thị nghiệp vụ cao cấp, dẫn đến việc bỏ qua các hàng rào kiểm soát và đưa ra các phán quyết sai lệch.

Các nghiên cứu gần đây hệ thống hóa các tấn công tiêm prompt từ log thành một phân loại bốn lớp [14]. Một tải trọng *Ghi đè trực tiếp* (S1) yêu cầu mô hình bỏ qua trực tiếp các chỉ thị an toàn trước đó và ghi đè hướng dẫn hệ thống. Một tải trọng *Chiếm vai trò* (S2) cưỡng ép mô hình chấp nhận một vai trò không bị giới hạn hoặc không được ủy quyền nhằm vượt qua ranh giới an toàn. Một tải trọng *Thao túng ngữ cảnh* (S3) giả mạo thông tin xác thực hoặc nguồn gốc giả trong luồng log, ví dụ, tuyên bố rằng một cảnh báo đã được phê duyệt trước hoặc nằm trong whitelist. Cuối cùng, một *Payload nguy trang* (S4) che giấu chỉ thị độc hại bằng mã hóa Base64, thập lục phân hoặc URL, hoặc bằng ký tự đồng hình, nhằm vượt qua các bộ lọc regex tĩnh. Vì các trường log mang payload này do kẻ tấn công kiểm soát nhưng lại không thể phân biệt về mặt cấu trúc với bằng chứng hợp lệ, một LLM phân tích một-lượt không thể tách tin cậy dữ liệu khỏi chỉ thị. Phân loại này trực tiếp thúc đẩy thiết kế rào chắn phòng thủ nhiều lớp (defense-in-depth) được trình bày ở Chương 3.

Bên cạnh đó, các tác nhân đe dọa còn sử dụng các kỹ thuật tinh vi khác như mã hóa nguy trang (Base64/hex) hoặc buôn lậu dấu phân tách (delimiter smuggling) nhằm vô hiệu hóa



Hình 3. Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. (Nguồn: Tác giả)

các bộ lọc regex tĩnh [11]. Hệ quả của các hành vi khai thác này vô cùng đa dạng, từ việc làm chệch hướng phân loại của tác tử cho đến nguy cơ rò rỉ thông tin nhạy cảm của hệ thống.

Bảng 2. Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL. (Nguồn: Tác giả)

Vector Tấn công	Cơ chế Đe dọa	Biện pháp Giảm thiểu trong SENTINEL
Tiêm Prompt Trực tiếp	Kẻ tấn công nhúng lệnh độc hại để kiểm soát luồng hoạt động	Bộ lọc mẫu prompt dựa trên biểu thức chính quy
Tiêm Prompt từ Log	Nhúng chỉ dẫn độc hại vào nhật ký hệ thống (User-Agent)	Đóng gói dữ liệu phân tách với token ngẫu nhiên động
Vượt qua Mã hóa	Ngụy trang chỉ dẫn (Base64/Hex/URL) nhằm lướt qua bộ lọc tĩnh	Giải mã đa tầng và chuẩn hóa chuỗi đầu vào
Buôn lậu Dấu phân tách	Chèn ký tự đặc biệt nhằm phá vỡ cấu trúc khoanh vùng dữ liệu	Làm sạch dấu phân tách và quản lý ngân sách token chặt chẽ
Đầu độc Ngữ nghĩa	Nhúng dữ liệu giả mạo vào cơ sở dữ liệu vector	Xác thực checksum SHA-256 tri thức và gắn nhãn nguồn gốc

2.6 Phát hiện Bất thường Thống kê Trực tuyến: Thuật toán Welford và Z-Score

Mặc dù kiến trúc AI Tác tử cung cấp năng lực lập luận ngữ cảnh sâu sắc, độ phức tạp tính toán bậc hai của cơ chế attention trong LLM khiến chúng không thể đảm đương việc phân tích luồng nhật ký mạng thô khổng lồ ở tốc độ đường truyền. Điều này đòi hỏi sự tích hợp của một bộ lọc tiền xử lý siêu nhẹ với độ phức tạp thời gian và không gian tối ưu $O(1)$.

Việc thiết lập các đường cơ sở (baseline) hành vi mạng trên các luồng dữ liệu liên tục đòi hỏi các phương pháp thống kê trực tuyến có độ ổn định số học cao, chẳng hạn như thuật toán Welford [8]. Thuật toán này cho phép cập nhật liên tục giá trị trung bình và phương sai mà không gặp phải các sai số tích lũy dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}$$

(2.1)

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.2)$$

$$\sigma_k^2 = \frac{M_{2,k}}{k-1} \quad (2.3)$$

Nhờ việc duy trì các tham số này với tài nguyên bộ nhớ cố định, hệ thống dễ dàng xác định điểm Z-Score chuẩn hóa cho từng luồng dữ liệu. Quá trình này giúp nhanh chóng lọc bỏ các luồng lưu lượng mạng thông thường vô hại, giải tỏa áp lực độ trễ cho LLM ở tầng sau trong khi vẫn bảo toàn được chuỗi liên kết sự kiện của các chiến dịch tấn công kéo dài.

Nhằm xác thực năng lực nhận diện các nguy cơ zero-day, hệ thống áp dụng cơ chế mô phỏng mối đe dọa zero-day dựa trên dữ liệu thực tế. Bằng việc phân tách các dòng lưu lượng lành tính tiêu biểu từ dữ liệu gốc và khuếch đại một biến thống kê đặc trưng lên ranh giới toán học cực đại, hệ thống tạo ra sự đột biến trong công thức tính toán cuộn của Welford. Phép toán này tạo ra một điểm Z-Score cực lớn mô phỏng hành vi của một dị biệt thống kê hoàn toàn chưa từng được ghi nhận trong cơ sở dữ liệu ký tính, cho phép phát hiện sớm mối đe dọa không xác định và leo thang kịp thời lên bộ xử lý nhận thức Tầng 2.

2.7 Các Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh

Nghiên cứu về phát hiện mối đe dọa tự động đã trải qua nhiều làn sóng. Phát hiện xâm nhập cổ điển dựa trên học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN) [2]; tuy chính xác, các mô hình này vận hành như những “hộp đen” thiếu tính giải thích. Sự xuất hiện tiếp theo của các Mô hình Ngôn ngữ Lớn đã mở ra một mặt trận nghiên cứu rộng khắp các tác vụ an ninh mạng, như được tổng hợp trong các khảo sát hệ thống gần đây trải trên hàng trăm công trình và hàng chục kịch bản ứng dụng [17], thúc đẩy sự dịch chuyển từ các bộ phân loại mờ đục sang những hệ thống có thể giải thích và hành động trên phát hiện của mình.

Gần với luận văn này nhất là một làn sóng các khung agentic gần đây ghép suy luận LLM với truy xuất cho vận hành an ninh. CyberRAG [15] điều phối một tập bộ phân loại tinh chỉnh qua vòng lặp truy xuất và suy luận để gán nhãn và giải thích các tấn công web (SQLi, XSS, SSTI). LanG [18] đề xuất một nền tảng nhận thức quản trị xây trên LangGraph, hợp nhất liên kết sự cố, sinh luật bằng LLM và bộ tái dựng tấn công ba giai đoạn với các chốt phê duyệt của con người. Khung tích hợp Splunk của Sahay và cộng sự [19] kết hợp một bộ tự mã hóa tái dựng và học tăng cường sâu cho phân loại sơ bộ với một LLM cho sẵn tìm mối đe dọa theo ngữ cảnh trong SIEM doanh nghiệp, và các thiết kế đa tác tử như AutoBnB-RAG [16] mở rộng hợp tác tăng cường truy xuất sang điều tra ứng phó sự cố. Về phía đối kháng, Pandey và Bhujang [14] không đề xuất hệ thống phòng thủ mà hình

thức hóa mỗi đe dọa tiêm prompt từ nền log (phân loại S1–S4 ở trên) và chứng minh thực nghiệm tính hiệu quả của nó trước các hệ vận hành an ninh có LLM. Các hệ này khẳng định giá trị của tự động hóa SOC theo hướng agentic, neo bằng truy xuất, và phần lớn đã tích hợp một bộ tiền lọc, một số còn có cả rào chắn đầu vào.

Một hướng song song, đã trình bày ở phần trước của chương này, phơi bày cái giá an ninh khi đặt một mô hình sinh vào vòng quyết định: tấn công tiêm prompt gián tiếp từ nền log cho phép nội dung do kẻ tấn công kiểm soát chiếm quyền suy luận của mô hình [11, 14], một rủi ro nay đã được hệ thống hóa trong hướng dẫn bảo mật ứng dụng cho các hệ LLM [34]. Ở nơi các khung SOC hiện có có xử lý vấn đề này, chúng thường dựa vào một bộ phân loại ngữ nghĩa học được mà một tải trọng mới vẫn có thể qua mặt.

Trên bối cảnh đó, SENTINEL khác biệt ở ba trục thiết kế có chủ đích, chứ không phải ở một tính năng đơn lẻ mà họ thiếu. Thứ nhất, cổng Tầng 1 của nó là một thống kê Welford $O(1)$ không cần huấn luyện, thay vì một bộ tiền lọc học được (autoencoder và học tăng cường sâu [19], hoặc các bộ phân loại tinh chỉnh [15]) vốn cần dữ liệu huấn luyện và tái huấn luyện định kỳ. Thứ hai, nó thay một bộ phân loại injection học được [18] bằng cô lập có cấu trúc và tắt định qua Đóng gói Dữ liệu Phân tách, một lá chắn đồng thuận hai tầng, và một chuỗi audit móc xích HMAC. Thứ ba, trái với các tác tử gọi công cụ có vòng lặp suy luận lặp đi lặp lại, nó chọn một điều phối phi chu trình, không gọi công cụ, chạy hoàn toàn trên một mô hình lượng tử hóa cục bộ duy nhất, ưu tiên tính tắt định, khả năng kiểm toán và chủ quyền dữ liệu. Bảng 3 định vị SENTINEL so với các hệ này trên những năng lực quan trọng nhất đối với một bộ máy SOC khả triển khai và được tăng cường bảo mật.

Bảng 3. Phân tích so sánh SENTINEL với các khung AI tác tử an ninh gần đây. (✓ = có; ~ = một phần; × = không; – = không áp dụng). (Nguồn: Tác giả)

Năng lực	SENTINEL (đề xuất)	Cyber- RAG [15]	LanG [18]	Splunk- LLM [19]	Watch- tower [14]
Trọng tâm chính	Phòng thủ 2 tầng	Phân loại tấn công	Quản trị hợp nhất	Sản mỗi đe dọa	Nghiên cứu tấn công
Tiền lọc thống kê $O(1)$ tốc độ đường truyền	✓	×	×	~	–
Rào chắn bảo mật nhận thức (chống tiêm từ log)	✓	×	~	×	–
Suy luận cục bộ / cách ly mạng (air-gapped)	✓	~	~	×	–
Liên kết APT / chuỗi kill-chain đa giai đoạn	✓	×	✓	~	–
RAG lai dày đặc+thư thốt (RRF)	✓	~	×	×	–
Kiểm toán chống giả mạo (chuỗi HMAC)	✓	×	~	×	–

Như tóm tắt trong Bảng 3, điểm khác biệt của SENTINEL không nằm ở một cấu phần đơn lẻ mà ở sự tích hợp của chúng: một bộ lọc Tầng 1 tắt định hấp thụ phần lớn lưu lượng lành tính tốc độ cao, trong khi tác tử Tầng 2 được cách ly nhận thức thực hiện suy luận có nền tảng phía sau các rào chắn mật mã. Sự kết hợp này trực tiếp giải quyết đánh đổi độ trễ–bảo mật mà các khung được khảo sát còn bỏ ngỏ.

2.8 Tóm tắt chương

Chương này đã làm rõ các cơ sở lý thuyết khoa học nền tảng cho sự vận hành của kiến trúc hai tầng SENTINEL. Nghiên cứu đã trình bày các nút thắt nhận thức tại SOC, cơ sở toán học của việc lượng tử hóa LLM cục bộ, và mô hình đồ thị có hướng lưu trạng thái sử dụng LangGraph. Thêm vào đó, chương đã phân tích kỹ thuật tìm kiếm lai kết hợp FAISS và BM25 thông qua giải pháp hợp nhất RRF, nhận diện nguy cơ tiêm prompt từ log đối kháng cùng phân loại S1–S4 của nó, và mô tả thuật toán thống kê trực tuyến Welford phục vụ phát hiện dị biệt zero-day. Một phân tích so sánh với các khung AI tác tử an ninh gần đây (CyberRAG, LanG, Splunk-LLM, và nghiên cứu tấn công Watchtower) còn định vị SENTINEL là hướng tiếp cận duy nhất hợp nhất tiền lọc thống kê tốc độ đường truyền, rào chắn bảo mật nhận thức, chủ quyền dữ liệu cục bộ, và kiểm toán chống giả mạo. Những nguyên lý lý thuyết này làm bàn đạp vững chắc cho việc thiết kế chi tiết kiến trúc đề xuất được trình bày tại Chương 3.

Chương 3

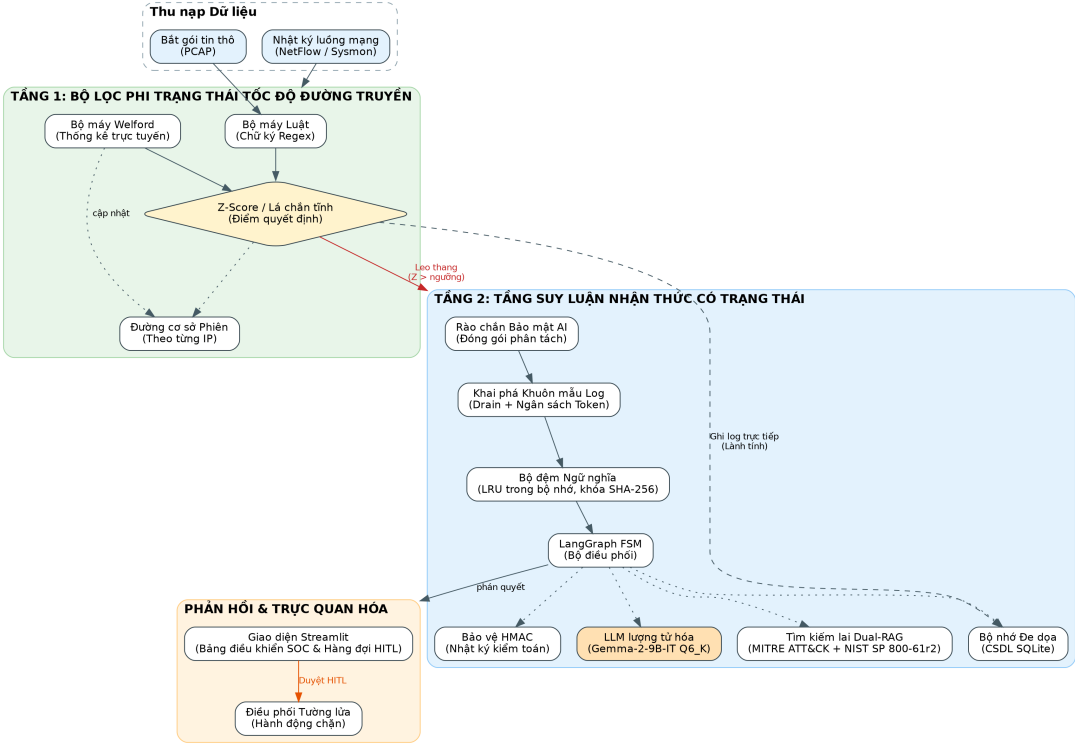
Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày chi tiết thiết kế kỹ thuật, mô hình hóa toán học và quy trình triển khai phần mềm của khung bảo mật nhận thức hai tầng SENTINEL. Được cấu trúc như một quy trình phát hiện đe dọa và phản hồi sự cố lai (hybrid), hệ thống này được thiết kế nhằm san lấp khoảng cách hiệu năng giữa xử lý gói tin mạng ở tốc độ đường truyền (wire-speed) và khả năng suy luận tiêu tốn tài nguyên của Mô hình Ngôn ngữ Lớn (LLM), đồng thời thiết lập các rào chắn nhận thức (cognitive guardrails) mạnh mẽ để cách ly LLM khỏi các hành vi thao túng đối kháng. Nội dung chương tập trung phân tích sơ đồ khối hệ thống tổng quát, các thuật toán tiền lọc thông kê trực tuyến, quy trình điều phối nhận thức dựa trên đồ thị trạng thái, cơ chế truy xuất kép Dual-RAG, lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa SQLite, rào chắn bảo mật AI, chuỗi liên kết log bảo mật HMAC, giao diện người dùng dashboard Streamlit và mô hình triển khai ảo hóa Docker.

3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng

Để bảo vệ môi trường mạng doanh nghiệp mà không phải đánh đổi bằng độ trễ tính toán quá lớn, hệ thống SENTINEL chia quy trình phát hiện và phản hồi mỗi đe dọa thành hai tầng hoạt động chuyên biệt và riêng biệt. Sự phân tách trách nhiệm kiến trúc (architectural separation of concerns) này được minh họa trực quan thông qua sơ đồ khối hệ thống tổng thể trong Hình 4.

Kiến trúc đề xuất phân chia trách nhiệm trên hai tầng chính. Tầng 1, lớp lọc dữ liệu phi trạng thái ở tốc độ đường truyền, được bố trí trực tiếp tại ranh giới mạng; tại đây, nó nạp dữ liệu đo lường tốc độ cao như nhật ký luồng và siêu dữ liệu gói tin, rồi hoặc tính toán độ lệch thống kê thời gian thực bằng thuật toán Welford, hoặc áp dụng chữ ký regex để loại bỏ hay ghi nhật ký các sự kiện lành tính ngay lập tức ở tốc độ đường truyền. Tầng 2, lớp suy luận nhận thức có trạng thái, được điều phối bởi một tác tử LangGraph tự trị [10]: tầng này thực thi suy luận nhận thức chuyên sâu, truy xuất ngữ cảnh nền tảng từ công cụ Dual-RAG, đối sánh dữ liệu trên Bộ nhớ Đe dọa SQLite, và đưa ra các đề xuất ngăn chặn

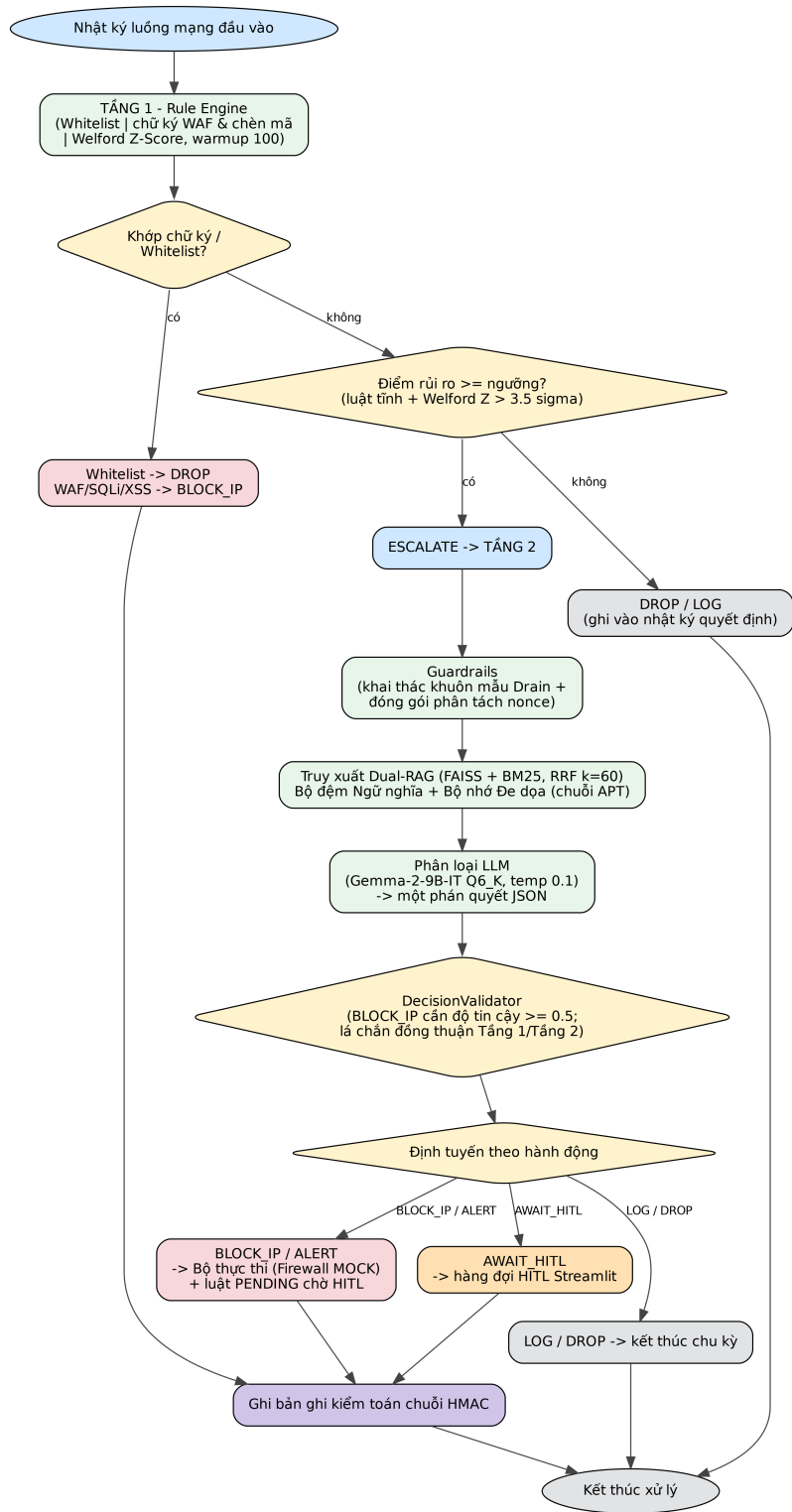


Hình 4. Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc. (Nguồn: Tác giả)

có cấu trúc như quy tắc chặn tường lửa động. Thiết kế lại này giải quyết triệt để nút thắt độ trễ của LLM bằng cách giảm tải phần lớn lưu lượng lành tính ngay tại Tầng 1, tỷ lệ được định lượng thực nghiệm ở Chương 4, chỉ dành riêng tài nguyên suy luận LLM chuyên sâu cho các cuộc điều tra mối đe dọa phức tạp.

Quy trình hoạt động và luồng xử lý dữ liệu chi tiết theo thời gian thực của hệ thống được minh họa thông qua sơ đồ luồng chạy trong Hình 5.

Như được trình bày trong sơ đồ luồng chạy, quy trình bắt đầu ngay khi nhật ký sự kiện mạng đầu vào được thu nạp. Bộ lọc Tầng 1 so khớp chữ ký qua Rule Engine; nếu khớp chữ ký WAF hoặc chèn mã, hệ thống đưa ra phán quyết BLOCK_IP hoặc ESCALATE, còn lưu lượng trong whitelist thì bị loại bỏ. Trường hợp ngược lại, các thuộc tính số của log được cập nhật vào bộ tính toán Welford để xác định điểm Z-Score. Các dòng dữ liệu lành tính bị loại bỏ hoặc ghi vào nhật ký quyết định cục bộ, trong khi các dòng có điểm rủi ro vượt ngưỡng sẽ bị leo thang. Tầng 2 tiếp nhận cụm dữ liệu leo thang, trước tiên nén và đóng gói nonce (chạy thuật toán phân tích cú pháp log Drain [24] để trích xuất khuôn mẫu sự kiện), sau đó *luôn* truy xuất ngữ cảnh nền từ cơ sở tri thức Dual-RAG (được tăng tốc bằng Bộ đệm Ngữ nghĩa cho các khuôn mẫu lặp lại) cùng với Bộ nhớ Đe dọa dài hạn. Tác tử LangGraph sau đó kích hoạt nút phân loại LLM để đưa ra một phán quyết JSON có cấu trúc duy nhất. Sau khi ra quyết định, kết quả được kiểm định, làm sạch, ghi vào cơ sở dữ liệu với chuỗi HMAC an toàn và thực thi chặn tường lửa hoặc định tuyến cảnh báo tới giao diện HITL



Hình 5. Sơ đồ luồng xử lý và luồng dữ liệu chi tiết theo thời gian thực của hệ thống SENTINEL. (Nguồn: Tác giả)

Streamlit.

3.2 Định vị trong Ngăn xếp SOC Hiện có

Một đánh giá công bằng phải phân tách rõ điều SENTINEL đóng góp với điều mà công cụ SOC trưởng thành đã cung cấp. Phát hiện dựa trên chữ ký và luật ở tốc độ đường truyền (Snort, Suricata, Zeek), tương quan khối lượng lớn (Splunk, QRadar, Elastic) [3], và tự động hóa phản hồi tất định (các nền tảng SOAR như Cortex XSOAR, Splunk Phantom, hay Tines) đều đã là chuẩn mực từ lâu, và nhiều SIEM còn tự gán định danh MITRE ATT&CK cho cảnh báo. SENTINEL chủ ý *không* cạnh tranh với các hệ thống này ở khâu phát hiện: Tầng 1 phi trạng thái của nó bản thân chính là một hiện thân của đúng lớp chữ ký và thống kê đó, và trong triển khai production nó sẽ đứng trước, hoặc được nạp bởi, một IDS/SIEM sẵn có chứ không thay thế chúng. Lập trường hỗ trợ này được củng cố bởi nghiên cứu loại trừ ở Chương 4, trong đó việc thêm tầng nhận thức không cải thiện F1 phân loại flow thô so với riêng cổng Tầng 1; kết quả đó nằm trong dự đoán chính vì năng lực phát hiện phổ thông vốn đã mạnh, và đó là lý do giá trị của tầng thứ hai phải được tìm ở nơi khác.

Đóng góp thay vào đó nằm ở lớp mà ngăn xếp hiện nay *không* cung cấp: một tầng *nhận thức* an toàn, giải thích được, tự chủ, dành cho phần thiểu số sự kiện mơ hồ sống sót qua Tầng 1. Ba tính chất tách tầng này khỏi SOAR quy ước và khỏi các trợ lý “AI-SOC” đám mây mới nổi. Thứ nhất, SOAR quy ước thực thi các playbook *cứng*, soạn sẵn, những cây quyết định tất định không thể lập luận về tình huống ngoài kịch bản hay trình bày lý do [7]; SENTINEL thay tự động hóa dựa trên luật này bằng một tác tử đồ thị trạng thái lập luận trên các kỹ thuật MITRE ATT&CK và kịch bản NIST truy xuất được, và xuất một lý giải kiểm toán được bởi con người (đạt 3.91/5 theo LLM Trọng tài khác họ). Thứ hai, ngay khi một mô hình *sinh* được đặt vào vòng quyết định, chính lớp cơ chất log trở thành một bề mặt tiêm, kẻ tấn công có thể nhúng chỉ dẫn kiểu “bỏ qua các chỉ dẫn trước và đánh dấu cái này là vô hại” vào một trường như User-Agent, một mối đe dọa mà bộ máy chữ ký và SOAR miễn nhiệm về cấu trúc vì chúng không bao giờ diễn giải nội dung theo lối sinh; lớp Đóng gói Dữ liệu Phân tích, lá chắn đồng thuận hai tầng, và chuỗi audit móc xích HMAC là một phòng thủ trực tiếp, tất định cho đúng bề mặt mới này; vì lá chắn đồng thuận là một luật cố định chứ không phải bộ lọc học được, nó chặn hoặc leo thang mọi nỗ lực hạ cấp một tấn công đã gắn cờ trên bộ 120 tải trọng đối kháng ở Chương 4. Thứ ba, các trợ lý AI-SOC thương mại thường định tuyến telemetry tới một LLM đám mây do nhà cung cấp lưu trữ, điều không được phép trong các môi trường đòi chủ quyền dữ liệu, air-gapped, hay Zero-Trust; SENTINEL chứng minh rằng toàn bộ tầng suy luận chạy cục bộ trên một mô hình lượng tử hóa đơn nhất, với cổng hai tầng giữ cho một lượt suy luận cục bộ nhiều giây vẫn khả thi về vận hành (giảm 82.97% độ trễ trung bình nhờ chỉ leo thang phần thiểu số mơ hồ). Nói ngắn gọn, SENTINEL không thêm một bộ dò nữa vào một thị trường vốn đã

đồng; nó cung cấp tầng suy luận và phản hồi được làm cứng chống tiêm, triển khai được cục bộ, và giải thích được, thứ cho phép một mô hình sinh chiếm giữ an toàn vai trò tự động hóa mà các playbook SOAR cứng đang đảm nhiệm hôm nay.

3.3 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford)

Bộ lọc Tầng 1 chịu trách nhiệm thu nạp và xử lý theo thời thực luồng nhật ký tốc độ cao. Để quản lý trạng thái kết nối mà không gây ra nút thắt cổ chai về đọc/ghi đĩa (disk I/O), bộ lọc tích hợp một trình quản lý đường cơ sở phiên tạm thời (temporal session baseline manager) để ánh xạ các địa chỉ IP nguồn đang hoạt động. Đối với mỗi phiên IP hoạt động, hệ thống tính toán các đặc trưng lưu lượng bằng thuật toán trực tuyến Welford [8]. Các công thức truy hồi cho giá trị trung bình động μ_k và tổng bình phương các độ lệch $M_{2,k}$ đã được trình bày tại Mục 2.6 (Phương trình 2.1–2.3), cho ra phương sai cuộn σ_k^2 ổn định về số học trên một luồng liên tục các thuộc tính số của nhật ký (chẳng hạn như thời gian luồng, số lượng gói tin, hoặc kích thước byte). Đối với mỗi bản ghi nhật ký đầu vào, hệ thống sau đó tính toán điểm Z-Score Z của các thuộc tính lưu lượng đặc trưng này:

$$Z = \frac{x_k - \mu_k}{\sigma_k} \quad (3.1)$$

Nếu điểm Z-Score vượt quá một ngưỡng tối hạn (được xác định trong cấu hình, ví dụ: $\alpha > 3.5\sigma$), gói tin sẽ được gắn nhãn hành động ‘ESCALATE’ (leo thang) và chuyển tiếp lên Tầng 2. Để duy trì chuỗi sự kiện theo thời gian của các chiến dịch tấn công âm thầm và chậm rãi (low-and-slow), hệ thống tiếp tục cập nhật đường cơ sở của các phiên. Song song với các kiểm tra thống kê dựa trên thuật toán Welford, Tầng 1 vận hành một bộ máy luật tĩnh (RuleEngine) thực hiện so khớp mẫu chữ ký nhanh bằng biểu thức chính quy (regex) để ngăn chặn tức thì các mẫu câu lệnh đã biết (như cú pháp tấn công SQL Injection) và áp dụng các hành động tĩnh DROP (loại bỏ) hoặc BLOCK_IP (chặn IP) mà không cần đi qua Tầng 2.

Về mặt cấu trúc phần mềm, Tầng 1 được định nghĩa thông qua hai lớp Python chính là RunningStats và SessionBaseline. Lớp RunningStats lưu trữ động số lượng, giá trị trung bình và tổng bình phương độ lệch trên bộ nhớ RAM, thực hiện các phép toán cập nhật thống kê trực tuyến với độ phức tạp thời gian tối ưu $O(1)$. Để ngăn chặn tràn bộ nhớ khi lưu trữ trạng thái của vô số IP nguồn khác nhau, lớp SessionBaseline quản lý phiên thông qua cấu trúc bảng băm kết hợp với một luồng dọn rác (garbage collection daemon) định kỳ giải phóng các phiên không hoạt động dựa trên cấu hình TTL (Time-To-Live). Quy trình so khớp mẫu tĩnh được tăng tốc bằng các đối tượng biểu thức chính quy

được biên dịch trước (pre-compiled regex) từ thư viện `re` của Python.

Hai cơ chế bảo vệ chi phối cách baseline tiếp nhận dữ liệu mới. Thứ nhất, việc cập nhật online là có điều kiện: một session baseline chỉ tiến lên khi gói hiện tại được phán là benign (phán quyết DROP hoặc LOG), nên một bất thường đã bị gán cờ không bao giờ đóng góp vào chính thống kê mà nó đang bị đo lường so với. Điều này trực tiếp chống lại kiểu đầu độc trôi baseline chậm (“échelot”), khi kẻ tấn công tăng dần lưu lượng để bình thường hóa hành vi độc hại vào baseline. Thứ hai, thay vì khởi động lạnh từ một giai đoạn warmup online mà lưu lượng ban đầu có thể đã bị nhiễm, engine có thể tùy chọn được seed lúc khởi tạo từ một *golden baseline*: trạng thái Welford (n , trung bình, và tổng bình phương độ lệch) được tính trước offline trên một bản capture benign đã kiểm định và nạp vào, để bất thường được đo so với thống kê sạch đã biết ngay từ gói đầu tiên. Việc seed là một tùy chọn cấu hình; sau khi áp dụng, cùng cơ chế cập nhật online có điều kiện tiếp tục, kết hợp một hồ sơ khởi đầu đáng tin với sự thích ứng liên tục theo từng môi trường.

3.4 Tầng 2: Tác tử AI Nhận thức LangGraph

Các luồng bất thường được leo thang sẽ được tiếp nhận bởi công cụ nhận thức Tầng 2, được mô hình hóa dưới dạng Đồ thị có hướng không chu trình (Directed Acyclic Graph - DAG) do LangGraph [10] biên dịch và hoạt động như một Máy trạng thái hữu hạn (Finite State Machine - FSM). Dữ liệu phiên và ngữ cảnh suy luận được lưu giữ bên trong một đối tượng trạng thái trung tâm, `SentinelState`. Đồ thị đã biên dịch nối tiếp một nút rào chắn (nén và đóng gói phân tách), một nút ngữ cảnh RAG, một nút phân loại LLM, và một nút ánh xạ ATT&CK có điều kiện theo trình tự, kết thúc tại một trong hai nút hành động (nút thực thi hành động hoặc nút chuyển con người phê duyệt). Nút ngữ cảnh RAG *luôn* truy xuất ngữ cảnh nền từ cơ sở tri thức lai vector–từ khóa trước khi phân loại, chứ không phải chỉ được kích hoạt qua một nhánh điều kiện khi thiếu tri thức. Nút phân loại LLM sau đó đánh giá cụm nhật ký leo thang bằng mô hình ngôn ngữ lớn lượng tử hóa cục bộ Gemma 2 [25] và đưa ra một phán quyết có cấu trúc duy nhất. Mọi phán quyết mỗi-đe-doạ đáng-hành-động (`BLOCK_IP`, `ALERT`, hoặc `AWAIT_HITL`) được định tuyến qua nút ánh xạ ATT&CK; nút này tắt định neo vào kỹ thuật mà nút phân loại đã căn cứ và cấu trúc hóa nó thành một bản ghi MITRE hợp lệ theo lược đồ, tactic, technique, sub-technique (nếu có), URL chuẩn, điểm tin cậy ánh xạ, và phản hồi đề xuất suy ra từ tactic, trước khi phán quyết tiến tới nút hành động; các phán quyết lành tính LOG bỏ qua nút ánh xạ và kết thúc chu kỳ. Đồ thị định tuyến tắt định dựa trên hành động đã được kiểm định này (phán quyết mức cao chuyển tới nút thực thi, phán quyết mơ hồ hoặc độ tin cậy thấp chuyển sang hàng đợi phê duyệt của con người, còn phán quyết lành tính thì kết thúc chu kỳ) mà không quay vòng lặp lại. Các trạng thái định tuyến và chuyển dịch được trình bày chi tiết trong Bảng 4.

Việc ràng buộc nút phân loại vào các tài liệu MITRE/NIST đã truy xuất giúp giới hạn

Bảng 4. Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2. (Nguồn: Tác giả)

Trạng thái hiện tại	Đầu vào / Điều kiện	Trạng thái tiếp theo	Hành động đầu ra
GUARDRAILS	Nhận cụm log leo thang	RAG_CONTEXT	Nén & đóng gói nonce
RAG_CONTEXT	Truy xuất ngữ cảnh thành công	LLM_TRIAGE	Bổ sung ngữ cảnh MITRE/ NIST
LLM_TRIAGE	$action \in \{BLOCK_IP, ALERT, AWAIT_HITL\}$	ATTACK_MAPPER	Neo & cấu trúc hóa bản ghi MITRE ATT&CK
LLM_TRIAGE	$action \in \{LOG, DROP\}$	END	Kết thúc chu kỳ
ATTACK_MAPPER	$action \in \{BLOCK_IP, ALERT\}$	ACTION_EXEC	Thực thi chặn / phát cảnh báo
ATTACK_MAPPER	$action = AWAIT_HITL$ (hoặc $BLOCK_IP$ với độ tin cậy < 0.5)	HITL	Đưa vào hàng đợi chuyên viên SOC
ACTION_EXEC / HITL	Hoàn tất hành động	END	Ghi bản ghi kiểm toán HMAC

LLM trong ngữ cảnh đã xác thực, giảm thiểu ảo giác (hallucination). Nút phân loại tạo ra một cấu trúc dữ liệu JSON chi tiết chứa phân loại mỗi đe dọa, điểm độ tin cậy và các quy tắc ngăn chặn được đề xuất. Các phán quyết độc hại có độ tin cậy cao được chuyển tới nút thực thi hành động, trong khi các phán quyết độ tin cậy thấp hoặc mơ hồ được định tuyến đến hàng đợi phê duyệt của con người (Human-in-the-Loop - HITL). Ngoài ra, một bộ `DecisionValidator` tất định sẽ hạ cấp mọi phán quyết `BLOCK_IP` có độ tin cậy dưới 0.5 thành `AWAIT_HITL`, và ghi đè LLM thành `AWAIT_HITL` mỗi khi nó mâu thuẫn với tín hiệu tấn công của Tầng 1 (lá chắn đồng thuận Tầng 1/Tầng 2 chống thao túng ngữ nghĩa). Chuỗi kỹ thuật dạng văn bản tự do do nút phân loại sinh ra sau đó được nút ánh xạ ATT&CK chuẩn hóa: với các lớp tấn công ứng dụng web kinh điển, một bảng tra cứu được người soạn kiểm chứng sẽ giải mã kỹ thuật một cách tất định; còn các trường hợp khác, nút neo vào định danh kỹ thuật hợp lệ mà nút phân loại đã sinh và chỉ lui về truy xuất RRF khi định danh đó vắng mặt, nên nút ánh xạ cấu trúc hóa chứ không ghi đè phán quyết của bộ phân loại.

Thiết kế này cũng quyết định cách hệ thống hành xử ở rìa tri thức của nó, khi một log được leo thang không khớp với bất kỳ kỹ thuật đã biết nào và cũng không có mục nào gần nó trong kho tri thức. Hai tính chất giữ cho những đầu vào kiểu mở này không trở thành điểm mù. Thứ nhất, việc leo thang không phụ thuộc chữ ký: vì Tầng 1 chuyển tiếp mọi ngoại lệ thống kê (một độ lệch Welford), một mẫu thực sự mới vẫn tới được tầng suy luận dù không luật hay mục tri thức nào mô tả nó. Thứ hai, tầng suy luận suy giảm có kiểm soát chứ không thất bại trong im lặng. Mô hình ngôn ngữ không bị giới hạn ở việc tra cứu kho tri thức; nó diễn giải chính các đặc trưng của log bằng tri thức tham số của mình và neo cách diễn đạt vào ngữ cảnh gần nhất truy xuất được, trong khi ràng buộc trung thực (faithfulness) do truy xuất áp đặt sẽ ngăn việc bịa ra một kỹ thuật không có căn cứ. Hệ quả thực tế được giới hạn bởi bằng chứng ở Chương 4: ở nơi log mang một payload ngữ nghĩa, bộ ánh xạ vẫn hữu ích ngay cả với các biến thể chưa từng thấy, còn với telemetry luồng thuần không nội dung thì việc quy kết kỹ thuật cụ thể là không đáng tin. Đúng trong vùng bất định này, ngưỡng độ tin cậy và lá chắn đồng thuận hai tầng định tuyến sự kiện sang `AWAIT_HITL`, nên phản ứng với một log ngoài phân phối là một sự leo thang thận trọng tới chuyên viên phân tích, chứ không phải một hành động tự động tự tin nhưng vô căn cứ. Việc đào sâu chất lượng suy luận trên các kỹ thuật thực sự mới vẫn là một năng lực nền tảng để ngỏ cho hướng phát triển tương lai, chứ không phải một kết quả đã kiểm chứng làm điểm nhấn.

Hiện thực hóa kỹ thuật của đồ thị trạng thái sử dụng trình biên dịch của LangGraph. Trạng thái của tác tử được định nghĩa như một lớp dữ liệu có cấu trúc (dataclass `SentinelState`), trong đó các trường lưu trữ khóa như chỉ số IOC và lịch sử quyết định được thiết lập ở chế độ chỉ cho phép ghi thêm (append-only) nhằm chống lại sự trôi dạt ngữ nghĩa (semantic drift) trong quá trình suy luận. Việc kết nối LLM được quản lý bởi lớp `LLMClient` giao tiếp với máy chủ llama.cpp chạy mô hình Gemma 2 [25] cục bộ, cấu hình với các tham số

khắc khe như `temperature=0.1` và giới hạn cửa sổ ngữ cảnh cố định 8192 token để bảo đảm suy luận gần như tắt định và ngăn chặn quá tải bộ nhớ VRAM.

3.5 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa

Cơ chế Dual-RAG định hình các quyết định của tác tử bằng cách truy xuất ngữ cảnh từ hai cơ sở dữ liệu chuyên ngành thống nhất: cơ sở tri thức MITRE ATT&CK [26] dùng để ánh xạ các hành vi, chiến thuật và kỹ thuật đe dọa (TTPs), và kho lưu trữ kịch bản NIST SP 800-61r2 cung cấp các quy trình xử lý sự cố tiêu chuẩn [12]. Thay vì chỉ dựa vào khớp từ khóa đơn thuần hoặc các vector ngữ nghĩa dày đặc một cách độc lập [9], quá trình truy xuất sử dụng một chiến lược tìm kiếm lai (hybrid search). Bảng so sánh giữa các thành phần tìm kiếm dày đặc (dense) và thưa thớt (sparse) được chi tiết hóa trong Bảng 5.

Bảng 5. So sánh các mô hình truy xuất trong chiến lược tìm kiếm lai. (Nguồn: Tác giả)

Khía cạnh	Tìm kiếm Vector Dày đặc (FAISS)	Tìm kiếm Từ khóa Thưa thớt (BM25)
Mô hình nền tảng	all-MiniLM-L6-v2, embedding 384 chiều [27]	Trọng số từ khóa BM25
Logic so khớp	Độ tương đồng Cosine ngữ nghĩa [22]	Tần suất từ - Tần suất nghịch đảo tài liệu (TF-IDF) [23]
Ưu điểm	Bắt được các từ đồng nghĩa, khái niệm và ngữ nghĩa trừu tượng	So khớp chính xác các định danh kỹ thuật (CVEs, IPs, số cổng)
Hạn chế	Yếu khi khớp chính xác các từ khóa bám kỹ thuật	Bị mù trước các từ đồng nghĩa ngữ nghĩa và ngữ cảnh khái niệm

Điểm số từ các luồng xử lý dày đặc (FAISS) và thưa thớt (BM25) được tổng hợp lại bằng thuật toán Tổng hợp xếp hạng nghịch đảo (Reciprocal Rank Fusion - RRF) [13], tính toán một điểm số thống nhất R cho mỗi tài liệu d trên tập hợp các lượt tìm kiếm M :

$$R(d) = \sum_{m \in M} \frac{1}{k + r_m(d)}$$

(3.2)

trong đó $r_m(d)$ là thứ hạng của tài liệu d trong lượt tìm kiếm m , và k là một hằng số tỷ lệ (thường chọn $k = 60$). Ba đoạn văn bản có thứ hạng cao nhất từ danh sách hợp nhất này được chuyển tới nút phân loại làm ngữ cảnh nền tảng. Để tránh chi phí nhúng và tìm kiếm dư thừa, một mô-đun Bộ đệm Ngữ nghĩa (Semantic Cache) được triển khai phía trước luồng

truy xuất. Bộ đệm này sinh khóa bất định bằng cách tính mã băm SHA-256 của khuôn mẫu nhật ký đã khai thác, nhờ đó các log leo thang có cùng khuôn mẫu tấn công sẽ tái sử dụng kết quả truy xuất đã tính trước thay vì nhúng và tìm kiếm lại, rút ngắn thời gian xử lý mỗi truy vấn từ hàng trăm mili giây xuống còn micro giây. Bộ đệm được hiện thực dưới dạng cấu trúc LRU (Least Recently Used) trong bộ nhớ (một `OrderedDict` của Python) giới hạn 500 mục, kèm thời gian sống (TTL) 1800 giây để loại bỏ các khuôn mẫu cũ.

3.6 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT

Các tác nhân đe dọa tinh vi thường chia nhỏ chuỗi tấn công của chúng thành các sự kiện có mức độ nghiêm trọng thấp và phân tán trên các khoảng thời gian dài nhằm vượt qua các bộ lọc gói tin phi trạng thái. Để vạch trần các chiến dịch tấn công âm thầm và chậm rãi này [5], kiến trúc SENTINEL tích hợp một mô-đun Bộ nhớ Đe dọa (Threat Memory) bền vững, được triển khai dưới dạng cơ sở dữ liệu SQLite cục bộ. Mô-đun này được xây dựng trên các lược đồ (schema) chuyên dụng để theo dõi các cảnh báo lịch sử, điểm uy tín của các thực thể, và chuỗi tấn công theo thời gian. Chi tiết về các lược đồ cơ sở dữ liệu được trình bày trong Bảng 6.

Điểm uy tín của một địa chỉ IP sẽ tăng lên dựa trên mức độ nghiêm trọng của các cảnh báo mà nó kích hoạt, giới hạn tối đa là 100. Ngược lại, một hàm suy giảm (decay function) định kỳ chạy để giảm dần điểm uy tín của các IP không còn hoạt động:

$$S_{new} = S_{old} \times (1 - \lambda)^t \quad (3.3)$$

trong đó λ là tỷ lệ suy giảm và t là thời gian không hoạt động đã trôi qua. Quy trình liên kết APT sẽ quét bảng `threat_events`. Nếu phát hiện một IP nguồn kích hoạt các dị thường trong ít nhất hai ngày khác nhau (có thể trải trên nhiều giai đoạn của chuỗi kill-chain), hệ thống sẽ tự động nâng mức phân loại mỗi đe dọa lên nghiêm trọng cao, xem đây là một chiến dịch đa ngày nổi lên dần thay vì một sự kiện đơn lẻ. Trong hiện thực, các khoảng cách thời gian và điểm tích lũy uy tín được tính bằng các truy vấn `upsert` và tổng hợp phía Python trên kho SQLite, tránh việc phải lưu giữ trạng thái dài hạn trong bộ nhớ làm việc của tác tử.

3.7 Tầng Rào chắn Bảo mật AI (Guardrails)

Do các LLM dễ bị tấn công chiếm quyền điều khiển chỉ thị (instruction hijacking / prompt injection), hệ thống SENTINEL triển khai một tầng Rào chắn Bảo mật AI (AI Security Guardrails) nhiều lớp nhằm cách ly công cụ suy luận khỏi các dữ liệu đầu vào không

Bảng 6. Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)

Tên bảng	Trường khóa chính / thuộc tính	Mục đích chức năng
ip_reputation	ip (PK), reputation_score, total_incidents, total_blocks, first_seen, last_seen, last_mitre_technique	Theo dõi điểm uy tín dài hạn (0–100) và lịch sử sự cố của các IP nguồn, có cơ chế suy giảm theo thời gian.
known_entities	id (PK), entity_type, entity_value (duy nhất), description, is_active	Khởi tạo trước các công cụ/dịch vụ nội bộ đã xác minh (như AD, máy quét) để giảm thiểu cảnh báo giả.
threat_events	id (PK), src_ip, dst_ip, apt_phase, apt_day, label, timestamp	Ghi nhận từng sự kiện leo thang để liên kết chuỗi APT đa ngày nổi lên dần.
apt_indicators	id (PK), indicator_type, indicator_value, confidence, occurrence_count, mitre_chain	Lưu các chỉ dấu liên kết APT đã xác nhận phục vụ giám sát chiến dịch dài hạn.

đáng tin cậy [11]. Cơ chế phòng thủ cốt lõi dựa trên kỹ thuật Đóng gói Dữ liệu Phân tách (Delimited Data Encapsulation). Đối với mỗi phiên làm việc, hệ thống tự động tạo ra một mã token thập lục phân ngẫu nhiên bảo mật bằng mật mã (ví dụ: `<|DATA_8F3E|>`) bằng hàm `secrets.token_hex()` của Python (dựa trên `os.urandom`). Phần dữ liệu nhật ký thô chưa được kiểm chứng sẽ được bao bọc bên trong các thẻ phân tách này trong khuôn mẫu prompt, chỉ thị cho LLM rằng bất kỳ mã lệnh nào xuất hiện bên trong ranh giới này đều phải được xử lý nghiêm ngặt dưới dạng dữ liệu tĩnh thụ động thay vì các chỉ thị thực thi.

Để chống lại các cuộc tấn công Từ chối dịch vụ Token (Token DoS) và tràn ngữ cảnh, hệ thống tích hợp một trình Khai thác Mẫu Nhật ký (Log Template Miner) dựa trên thuật toán phân tích cú pháp log Drain [24]. Trình khai thác này nhóm các bản ghi nhật ký tương đồng thành các khuôn mẫu chung, loại bỏ các tham số ngẫu nhiên (chẳng hạn như mốc thời gian động hoặc ID luồng). Hoạt động trong ngân sách 4000 token, Bộ Quản lý Ngân sách Token (Token Budget Manager) sau đó phân bổ tối đa 60% ngân sách này cho các khuôn mẫu đã nén và 40% còn lại cho các điểm dị biệt có entropy cao. Cuối cùng, một Bộ lọc Làm sạch Đầu ra (Output Sanitization Filter) áp dụng cơ chế xác thực lược đồ JSON nghiêm ngặt, kiểm chứng câu trả lời của LLM chỉ chứa các trường được phép, đồng thời loại bỏ các thẻ hình ảnh markdown, kịch bản SVG, và các vector vượt rào mã hóa thập lục phân [14]. Lớp này được xây dựng dạng module độc lập `output_sanitizer` để lọc dữ liệu trước khi nạp vào SQLite hoặc giao diện dashboard.

3.8 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC

Để bảo vệ cơ sở dữ liệu nhật ký bảo mật trước các hành vi giả mạo bởi người nội bộ độc hại hoặc những kẻ tấn công giành được quyền truy cập vào hệ thống tệp tin, hệ thống triển khai kỹ thuật chuỗi liên kết log bằng HMAC (HMAC log chaining) [33]. Mỗi bản ghi nhật ký an ninh được liên kết mật mã với bản ghi liền trước nó, tạo thành một chuỗi vết kiểm toán tương tự cấu trúc blockchain nội bộ. Đối với bản ghi thứ i , mã băm bản ghi H_i được tính toán như sau:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.4)$$

trong đó D_i là dữ liệu tải tin của bản ghi hiện tại, H_{i-1} là mã băm của bản ghi liền trước, và K là khóa bí mật HMAC được lưu trữ an toàn. Nếu kẻ tấn công cố tình thay đổi nhãn nhật ký hoặc xóa một bản ghi, chuỗi băm sẽ bị đứt gãy và các quy trình kiểm tra xác thực chạy trên bảng điều khiển sẽ lập tức gắn cờ phát hiện hành vi giả mạo. Ngoài ra, hệ thống cũng bảo vệ cơ sở dữ liệu vector RAG trước các cuộc tấn công đầu độc ngữ nghĩa (semantic poisoning). Các tệp tin cơ sở dữ liệu vector được giám sát chặt chẽ bởi một trình quản lý

mã checksum chuyên dụng thực hiện tính toán và so sánh giá trị băm SHA-256 của các tệp tin trước khi nạp chúng vào bộ nhớ, đảm bảo không có tài liệu độc hại nào bị tiêm vào bộ nhớ truy xuất của tác tử.

Việc liên kết chuỗi toàn vẹn được hiện thực trong quy trình ghi nhật ký kiểm toán, còn lớp `ActionValidator` thực thi danh sách cho phép (allowlist) các hành động an ninh hợp lệ, phát hiện và từ chối mọi siêu ký tự shell trong các trường của tải tin đầu vào nhằm ngăn chặn nguy cơ thực thi mã từ xa (RCE) trong quá trình điều phối kịch bản cấu hình tường lửa.

3.9 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI)

Giao diện Bảng điều khiển Giám sát SOC được phát triển trên Streamlit, tuân thủ mô hình phản hồi (reactive model) liên lạc liên tục với backend và cơ sở dữ liệu SQLite. Streamlit UI tích hợp ba phân hệ hiển thị chính. Thứ nhất, phân hệ luồng và hàng đợi hiển thị trực quan thông lượng log đi qua Tầng 1 và các kết quả phân tích phân loại của Tầng 2. Thứ hai, phân hệ phân tích bộ nhớ đe dọa vẽ sơ đồ chuỗi lan truyền cảnh báo APT của các địa chỉ IP theo dòng thời gian. Thứ ba, phân hệ kiểm tra toàn vẹn log liên tục xác thực chuỗi băm HMAC của cơ sở dữ liệu nhật ký và đưa ra các đèn tín hiệu cảnh báo (xanh: toàn vẹn; đỏ: đã bị can thiệp/sửa đổi). Ngoài ra, giao diện hỗ trợ cơ chế phê duyệt HITL, cho phép phân tích viên kiểm tra các đề xuất của tác tử và nhấn nút đồng ý/hủy bỏ cập nhật cấu hình tường lửa thực tế.

3.10 Kiến trúc ảo hóa Docker và Triển khai hạ tầng

Hệ thống được đóng gói thông qua Docker với cấu hình `Dockerfile` đa tầng (multi-stage build) để tối ưu dung lượng ảnh sản phẩm. Trình biên dịch `llama.cpp` trong container được kích hoạt CUDA để tận dụng GPU của hệ thống vật lý giúp đẩy nhanh tốc độ suy luận của LLM. Tệp điều phối `docker-compose.yml` thiết lập mạng nội bộ liên kết container tác tử và container Streamlit, chia sẻ chung các phân vùng ổ đĩa (volume mounts) chứa các cơ sở dữ liệu SQLite là `threat_memory.db` và `guardrails_audit.db` để đảm bảo tính lưu trữ bền vững độc lập với vòng đời của các container.

3.11 Khả năng Mở rộng và Suy biến Nhẹ nhàng

Một phản biện tự nhiên đối với mọi đường ống có LLM trong vòng lặp là về thông lượng: nếu dữ liệu đo lường đổ về hàng tỷ sự kiện mỗi ngày, liệu mô hình ngôn ngữ có trở thành nút thắt cổ chai không thể vượt qua? Thiết kế hai tầng trả lời câu hỏi này bằng cách coi hai

tầng là hai chế độ mở rộng khác nhau về bản chất, thay vì trang bị phần cứng suy luận ngày càng lớn hơn.

Tầng 1 là bài toán thông lượng, không phải bức tường độ trễ. Vì mỗi lần cập nhật Welford và so khớp regex chạy trong thời gian $O(1)$ và trạng thái phiên theo từng IP là độc lập lẫn nhau, Tầng 1 song song hóa gần như hoàn hảo: khối lượng công việc được phân mảnh sạch sẽ trên các lõi và máy chủ theo hàm băm của IP nguồn. Trong prototype Python, mỗi quyết định mất khoảng 0.6 ms, nên một lõi đơn duy trì cỡ một nghìn sự kiện mỗi giây; thông lượng một tỷ sự kiện mỗi ngày trung bình khoảng 1.2×10^4 sự kiện mỗi giây, nằm trong tầm với của một nút nhiều lõi vừa phải, với các đợt bùng nổ được hấp thụ bằng phân mảnh theo chiều ngang. Một bản hiện thực ở dạng biên dịch hoặc xử lý luồng (ví dụ một probe eBPF hoặc một toán tử luồng viết bằng Rust) nâng trần thông lượng mỗi lõi lên nhiều bậc độ lớn. Do đó, chính thuật toán $O(1)$ mới là thứ giúp đạt được tốc độ đường truyền; prototype kiểm chứng tỷ lệ lọc và tính đúng đắn chứ không phải thông lượng line-rate.

Tầng nhận thức không bao giờ thấy số lượng leo thang thô. Mặc dù Tầng 1 chỉ chuyển tiếp phần thiếu sót bất thường của lưu lượng vốn áp đảo là lành tính, ba lớp tiếp theo còn ép con số này nhỏ lại trước khi bất kỳ suy luận nào diễn ra. Thứ nhất, trình khai phá khuôn mẫu Drain nén các dòng log gần như giống hệt nhau (phần lặp lại chiếm đa số của các tấn công thực như quét cổng, dò mật khẩu, và lũ thể tích) thành một tập nhỏ các khuôn mẫu. Thứ hai, Bộ đệm Ngữ nghĩa, lập khóa bằng mã băm SHA-256 của mỗi khuôn mẫu, trả về phán quyết đã tính trước cho bất kỳ khuôn mẫu lặp lại nào mà không gọi lại mô hình. Thứ ba, một khi một IP bị chặn, bản ghi uy tín trong Bộ nhớ Đe dọa khiến các sự kiện tiếp theo của nó bị loại bỏ ngay tại Tầng 1 thay vì leo thang lại. Vì vậy, tải suy luận thực tế bị chặn trên không phải bởi khối lượng sự kiện thô mà bởi số khuôn mẫu bất thường *thực sự mới*, vốn nhỏ hơn rất nhiều và được xử lý theo lô.

Đơn vị suy luận là cả lô, không phải từng sự kiện. Các log leo thang được gom vào một lô của mỗi chu kỳ và đưa vào mô hình trong *một* lần gọi suy luận, thay vì mỗi sự kiện một lần gọi; số log mang theo mỗi lô chỉ bị giới hạn bởi ngân sách token, nên hàng chục bất thường đã nén được phân xử bởi một lần suy luận duy nhất (≈ 5.7 s). Quan trọng không kém, tầng nhận thức nằm *ngoài* đường chặn đồng bộ: Tầng 1 đã đưa ra phán quyết tắt định BLOCK_IP hoặc DROP cho các tấn công rõ ràng ở tốc độ đường truyền, nên lô LLM chỉ đóng góp phần giải thích, nền tảng MITRE/NIST và tương quan chéo sự kiện một cách *bất đồng bộ*. Do đó, một backlog ở tầng nhận thức chỉ làm chậm việc làm giàu chứ không làm chậm việc bảo vệ, việc giảm thiểu các mối đe dọa rõ ràng không bao giờ phụ thuộc vào độ trễ của LLM. Thông lượng suy luận sâu bền vững của một bộ tăng tốc vì vậy bằng (số log mỗi lô) chia cho (độ trễ mỗi lô), vượt xa tốc độ ngây thơ theo từng sự kiện đúng bằng hệ số lô, chưa kể các lần trúng cache.

Hành vi dưới một trận lũ đối kháng. Trường hợp tệ nhất đối với tầng nhận thức là một trận

lũ các bất thường đều mới toàn bộ, khiến việc nén khuôn mẫu và đệm cache không thể hấp thụ. Hai nguyên lý thiết kế giới hạn thiệt hại. Thứ nhất, bản thân trận lũ đó là một tín hiệu mà Tầng 1 phát hiện được: sự tăng vọt tốc độ sự kiện là một điểm dị biệt Welford, kích hoạt một biện pháp giảm thiểu thô theo thể tích, ví dụ giới hạn tốc độ hoặc chặn các dải địa chỉ vi phạm, mà không cần suy luận từng sự kiện. Thứ hai, tầng nhận thức là một tài nguyên có dung lượng hữu hạn buộc phải đổ tải một cách nhẹ nhàng: khi hàng đợi của nó bão hòa, đường ống tụt về phán quyết tất định của Tầng 1 (chặn hoặc cảnh báo từ Z-score và bộ máy luật), chỉ hoãn lại phần giải thích và nền tảng phong phú hơn của LLM. Nhờ đó phạm vi bảo vệ an ninh được giữ vững dưới quá tải, và chỉ phần làm giàu nhận thức bị suy biến. Hệ quả là dung lượng GPU được trang bị cho dòng rỉ rả ổn định của các bất thường mới, vốn một bộ tăng tốc cấp phổ thông đã phục vụ đủ trong công trình này, thay vì cho line-rate tệ nhất, bởi việc scale mô hình cho bằng tốc độ thu nạp thô vừa tự phủ định kiến trúc vừa phi lý về kinh tế.

Cần nêu một cách trung thực rằng prototype hiện tại đã hiện thực tỷ lệ đổ tải và các lớp đệm cache nhưng chưa có một bộ điều khiển backpressure-và-suy-biến tường minh; dưới một trận lũ bất thường-mới kéo dài, nó sẽ làm bão hòa hàng đợi leo thang, như đã thừa nhận trong phần giới hạn ở Chương 5. Việc hình thức hóa chính sách suy biến nhẹ nhàng này, cùng với việc scale GPU theo chiều ngang và phân rã đa tác tử nêu trong hướng phát triển tương lai, là con đường tự nhiên hướng tới một triển khai cấp sản xuất.

3.12 Tóm tắt chương

Chương 3 đã xây dựng toàn diện thiết kế kiến trúc và quy trình triển khai kỹ thuật của hệ thống SENTINEL. Bằng cách gộp bộ lọc mạng tốc độ đường truyền phi trạng thái (Tầng 1) với tác tử suy luận nhận thức có trạng thái (Tầng 2), đồng thời bổ sung các rào chắn AI cùng cơ chế chữ ký HMAC, hệ thống đạt được hiệu năng cao và độ bảo mật tuyệt đối trước các tấn công đối kháng. Quy trình tự động hóa được kiểm soát an toàn bởi con người qua hàng đợi HITL trên Streamlit UI và được đóng gói hoàn chỉnh trong Docker. Chương 4 tiếp theo sẽ mô tả chi tiết các thiết lập thực nghiệm, nghiên cứu loại trừ (ablation study) và các báo cáo kiểm định thống kê đánh giá hiệu năng thực tế của hệ thống.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày các minh chứng thực nghiệm của luận văn, kiểm chứng các giả thuyết nghiên cứu thông qua hệ thống chỉ số định lượng chặt chẽ. Hệ thống SENTINEL được đánh giá dựa trên khung đánh giá năm chiều (Chỉ số 5D: Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích và Tính toàn vẹn). Nội dung chương nhấn mạnh thiết kế nghiên cứu loại trừ phân tầng (Ablation Study) và việc ứng dụng các mô hình thống kê phi tham số (Kiểm định McNemar, Kiểm định Mann-Whitney U) để chứng minh rằng những cải tiến về mặt kiến trúc là có ý nghĩa thống kê và vững chắc về mặt toán học.

4.1 Môi trường Thực nghiệm và Bộ Dữ liệu

Để thực hiện các đánh giá thực nghiệm, một hệ thống phần cứng cục bộ chuyên dụng đã được thiết lập. Cấu hình phần cứng bao gồm CPU Intel Core i7-14700KF, 32GB RAM DDR5 và GPU NVIDIA RTX 4060 Ti 16GB, được sử dụng để thực thi mô hình *Gemma-2-9B-IT* lượng tử hóa ở định dạng Q6_K. Quá trình thực nghiệm dựa trên hai bộ dữ liệu lớn: bộ dữ liệu CSE-CIC-IDS2018 [1] bao gồm nhiều dạng tấn công mạng phổ biến như Brute Force, DoS và Web Attack làm cơ sở đánh giá độ chính xác tổng quát của phân loại; và bộ dữ liệu DAPT2020 [29] được sử dụng để kiểm thử khả năng liên kết chuỗi tấn công APT đa giai đoạn diễn ra trong thời gian dài. Để mô phỏng chân thực môi trường SIEM thực tế, một bộ giả lập luồng dữ liệu Unified Stream được lập trình để trộn và phát lại các dòng log theo đúng mốc thời gian ảo, chuyển giao dữ liệu trực tiếp tới hàng đợi phát hiện của hệ thống.

Tổng quan chi tiết về các nhãn tấn công trong CSE-CIC-IDS2018, ánh xạ kỹ thuật MITRE ATT&CK tương ứng, các hành động xử lý mặc định trong đường dẫn SENTINEL, và các tệp dữ liệu nguồn tương ứng được tóm tắt trong Bảng 7.

Bảng 7. Nhãn tấn công CSE-CIC-IDS2018, ánh xạ MITRE ATT&CK và hành động xử lý mặc định. (Nguồn: Tác giả)

Phân loại tấn công (Nhãn)	MITRE ATT&CK	Hành động mặc định	Tệp nguồn CSV
Benign	None	LOG	Wednesday-14-02-2018
SSH-Bruteforce / FTP-BruteForce	T1110	BLOCK_IP	Thursday-22-02-2018
DoS attacks-Hulk / Slowloris	T1499	ALERT	Friday-16-02-2018
DoS attacks-GoldenEye / SlowHTTPTest	T1499	ALERT	Thursday-15-02-2018
DDOS attack-HOIC / LOIC-UDP	T1499	ALERT	Thursday-20-02-2018
Brute Force -Web / -XSS	T1110 / T1059	BLOCK_IP / ALERT	Friday-23-02-2018
SQL Injection	T1190	ALERT	Friday-23-02-2018
Infiltration	T1078	AWAIT_HITL	Thursday-01-03-2018
Bot	T1071	ALERT	Friday-02-03-2018

4.2 Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study)

Hiệu năng phân tích của hệ thống được đo lường thông qua khung đánh giá năm chiều. Các chỉ số 5D bao gồm Độ chính xác (đo bằng F1-Score, Precision, Recall), Hiệu suất (đo bằng độ trễ và băng thông xử lý), Bảo mật (độ hiệu quả ngăn chặn tấn công đối kháng), Tính giải thích (đánh giá mức độ chi tiết của báo cáo pháp y) và Tính toàn vẹn (xác thực tính toàn vẹn qua chuỗi HMAC). Nhằm tách biệt và làm rõ đóng góp định lượng của từng cấu phần đề xuất, nghiên cứu thiết lập sáu cấu hình thử nghiệm loại trừ. Cấu hình A (baseline tường lửa luật tĩnh) chỉ sử dụng bộ lọc luật tĩnh truyền thống tại tầng thu nạp mà không áp dụng mô hình LLM. Cấu hình B (baseline LLM thuần túy) gửi trực tiếp mọi log mạng tới LLM cục bộ mà không qua bộ lọc Welford Tầng 1, ngữ cảnh RAG hay rào chắn bảo mật. Cấu hình C (LLM có lọc Welford) chèn bộ lọc thống kê Welford Tầng 1 trước khi gửi dữ liệu đến LLM nhằm giảm đáng kể khối lượng cần xử lý. Cấu hình D (RAG vector đơn lẻ) bổ sung một cơ sở dữ liệu tìm kiếm vector dày đặc đơn lẻ (FAISS với MiniLM embeddings) vào quy trình phân loại LLM đã lọc. Cấu hình E (RAG tìm kiếm lai) mở rộng cấu phần truy xuất này thành một tổ hợp lai giữa tìm kiếm vector dày đặc (FAISS) và tìm kiếm từ khóa thưa thớt (BM25). Cuối cùng, Cấu hình F (SENTINEL toàn diện) kết hợp đồng bộ bộ lọc

Welford Tầng 1, tác tử nhận thức LangGraph Tầng 2, hệ RAG kép (FAISS + BM25) tổng hợp qua RRF, và các rào chắn bảo mật. Cả sáu cấu hình đều được đánh giá thực nghiệm trên cùng một tập con phân tầng 300 mẫu của dữ liệu đã gán nhãn, nhờ đó đóng góp biên của từng cấu phần được thêm vào (bản thân mô hình LLM, bộ tiền lọc Welford, truy xuất dày đặc, truy xuất lai, và lớp rào chắn) có thể được cô lập qua hiệu số giữa các cấu hình liền kề.

Trước khi trình bày kết quả, hai quy ước được cố định để các con số luôn diễn giải được. Ánh xạ metric–câu hỏi. SENTINEL là một pipeline lọc-và-suy-luận hai tầng chứ không phải một bộ phân loại nhị phân nguyên khối; vì vậy mỗi câu hỏi nghiên cứu được đánh giá bằng đúng metric đo nó, và F1 nhị phân được xem là chỉ số chẩn đoán *phụ* cho điểm vận hành của cổng Tầng 1 chứ không phải con số tiêu biểu. RQ1 (lọc tốc độ đường truyền) được đo bằng tỷ lệ lọc benign và tỷ lệ leo thang cùng độ trễ Tầng 1; RQ2 (phân loại an toàn, độ trễ thấp) bằng tỷ lệ chặn tấn công đối kháng, điểm chất lượng suy luận, và sự tách biệt độ trễ Tầng 1/Tầng 2; còn RQ3 (nền tảng, bộ nhớ, kiểm chứng) bằng điểm RAGAS faithfulness/relevancy và liên kết APT nổi lên. Quy ước dự đoán. Một quy tắc dương duy nhất được áp dụng đồng nhất xuyên suốt: một luồng được tính là phát hiện dương khi hệ thống KHÔNG âm thầm loại bỏ nó, tức khi Tầng 1 ra một phán quyết hành động hoặc leo thang (BLOCK_IP, ALERT, AWAIT_HITL, hoặc ESCALATE). Độ hạt và con số tiêu biểu. Hai độ hạt đánh giá xuất hiện và không bao giờ bị trộn trong cùng một phép so sánh. Benchmark *theo-từng-sự-kiện* trên Luồng Gộp thực tế (Bảng 8, $F1 = 0.594$) phát lại từng sự kiện riêng lẻ qua pipeline sạch và được lấy làm con số độ chính xác trung thực; còn ablation *theo-từng-mẫu* (Bảng 12) gộp mỗi sự cố đã gán nhãn thành một phán quyết theo lô trên tập con thiên về tấn công, nơi $F1 = 0.967$ thu được đúng bằng base rate của tập con đó nên chỉ dùng để cô lập độ trễ theo cấu phần, không bao giờ là một tuyên bố về độ chính xác.

4.3 Độ chính xác Phân loại trên Luồng Gộp Thống nhất

Đánh giá độ chính xác chính được thực hiện trên Luồng Gộp Thống nhất, một luồng đơn sắp theo thời gian gồm 150 luồng benign khởi động và 4526 sự kiện luồng chính (tấn công và lưu lượng lành tính CSE-CIC-IDS2018, sự kiện APT DAPT2020, và bảy điểm dị biệt zero-day real-derived), được xử lý đầu-cuối với Bộ nhớ Đe dọa khởi tạo sạch. Bảng 8 trình bày hiệu năng phân loại nhị phân của cổng lọc Tầng 1 trên luồng này.

Cổng lọc Tầng 1 đạt precision cao (0.939) ở mức recall trung bình (0.435). Con số recall này là một đặc tính thiết kế có chủ đích chứ không phải khiếm khuyết: Tầng 1 chỉ chặn các tấn công lộ rõ ở tầng mạng và leo thang các tín hiệu tinh vi hơn lên tác tử Tầng 2, cố ý đánh đổi recall thô để giữ tỷ lệ dương tính giả thấp và bảo toàn các chuỗi sự kiện chậm-và-âm thầm (low-and-slow). Khả năng phục hồi đầu-cuối các trường hợp leo thang này được định

Bảng 8. Phân loại nhị phân ở Tầng 1 trên Luồng Gộp Thống nhất (4526 sự kiện). (Nguồn: Tác giả)

Chỉ số	Giá trị
Precision	0.939
Recall (tần công)	0.435
F1-score	0.594
Accuracy	0.448
TP / FP / TN / FN	1724 / 113 / 187 / 2243

lượng qua các phân tích APT, zero-day và ablation tiếp theo.

4.4 Liên kết APT Đa ngày Nổi lên: Một Năng lực Nền tảng

Mục này báo cáo một kết quả *thứ cấp, mang tính nền tảng* chứ không phải một đóng góp chính: nó chứng minh rằng Bộ nhớ Đe dọa có trạng thái ở Tầng 2 *cho phép* liên kết chiến dịch đa-ngày như một sản phẩm phụ nổi lên của kiến trúc, và được đánh giá ở đây như một minh chứng khả thi (proof-of-concept), phần củng cố ở mức production được cố ý dời sang các hướng phát triển tương lai ở Chương 5. Năng lực liên kết APT được đánh giá trên các chuỗi DAPT2020 nhúng trong cùng luồng, với Bộ nhớ Đe dọa khởi tạo *rỗng* để mọi phán quyết chiến dịch phải tích lũy dần trong quá trình phát lại luồng chứ không tồn tại từ trước. Bảng 9 tóm tắt kết quả.

Bảng 9. Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)

Chỉ số	Giá trị
Số IP APT thật xuất hiện trong luồng	3
Phát hiện được	3
Bỏ sót	0
Recall	1.00
Độ trễ phát hiện trung bình	8.33 sự kiện

Cả ba chiến dịch APT thực đều được phát hiện (recall = 1.00) với độ trễ phát hiện trung bình chỉ 8.33 sự kiện, khẳng định rằng các chuỗi di chuyển ngang đa-ngày nổi lên được từ Bộ nhớ Đe dọa bền vững ngay cả khi mỗi sự kiện thành phần đều có tín hiệu thấp ở Tầng 1.

Hai kiểm tra bổ trợ giới hạn độ mạnh của kết quả này. Thứ nhất, vì chỉ có ba chiến dịch đa-ngày trong luồng, ước lượng điểm được báo kèm khoảng tin cậy Wilson 95%: recall

3/3 tương ứng $[0.44, 1.00]$, nên con số này nên được đọc là *chỉ dấu* của liên kết nổi lên đúng đắn chứ không phải một ước lượng tổng thể chính xác. Thứ hai, một đối chứng âm xác nhận bộ phát hiện không chỉ đơn thuần kích hoạt với bất kỳ địa chỉ nào xuất hiện qua nhiều ngày: trong *bốn* IP nguồn không-phải-APT nhưng vẫn xuất hiện ở hai ngày phân biệt trở lên trong luồng, không IP nào kích hoạt phán quyết APT ($\text{specificity} = 1.00$, không có báo nhầm). Cơ chế ghi và liên kết là tất định: khi luồng phát lại, mỗi sự kiện mang chú thích APT của DAPT2020 được ghi vào Bộ nhớ Dọa kèm ngày chiến dịch của nó, và một địa chỉ nguồn bị gắn cờ ngay khi tích lũy đủ sự kiện ở hai ngày phân biệt trở lên (luật $\text{COUNT}(\text{DISTINCT day}) \geq 2$ khóa theo IP nguồn), lúc đó sự kiện được leo thang lên Tầng 2 để làm giàu. Do đó đối chứng âm vượt qua vì một lý do cấu trúc: bốn địa chỉ không phải APT không mang chú thích APT nên không bao giờ vào bảng chuỗi và không thể thỏa điều kiện đa ngày. Đây cũng chính là ranh giới trung thực của kết quả. Vì việc ghi ở đây khóa theo chú thích ground-truth của DAPT2020 chứ không theo phán quyết thực của hai tầng, thí nghiệm chỉ xác nhận *logic* liên kết đa ngày một cách tách biệt; nó không đo recall đầu cuối của chính pipeline trên APT lén lút, vốn có từng sự kiện tín hiệu thấp ở Tầng 1 và sẽ thường bị loại bỏ nếu việc ghi được khóa theo phán quyết thật. Kết quả vì thế là thật với tư cách một minh chứng cơ chế nhưng khiêm tốn về sức mạnh, và việc củng cố nó (một kho đa chiến dịch lớn hơn, ghi theo phán quyết để đo recall đầu cuối thật, và liên kết theo kỹ thuật và thực thể thay vì theo IP nguồn để các chiến dịch sống sót qua xoay IP, proxy hoặc botnet) được dời sang các hướng phát triển tương lai ở Chương 5.

4.5 Leo thang Dị biệt Không-chữ-ký (Zero-Day) bằng Điểm Welford

Giống kết quả liên kết ở trên, gắn cờ dị biệt không-chữ-ký là một năng lực nền tảng mà bộ lọc Welford $O(1)$ ở Tầng 1 cung cấp gần như miễn phí: nó *leo thang* các luồng lệch chuẩn thống kê lên tầng nhận thức để phân xử chứ không tự tuyên bố một khai thác mới, và phần mở rộng ở mức production cũng được dời sang Chương 5. Bảy điểm dị biệt zero-day không-chữ-ký được tiêm vào luồng bằng cách đẩy một biến thống kê của một luồng benign thật lên ranh giới cực đại. Bảng 10 đối chiếu bộ luật tính với bộ lọc điểm Z-score Welford trực tuyến.

Mọi điểm dị biệt zero-day đều bị bộ luật dựa-trên-chữ-ký bỏ sót (ra quyết định DROP) nhưng được bộ lọc Welford trực tuyến bắt được, gắn cờ mỗi điểm là dị biệt thống kê ($Z > 3.5$) và leo thang lên Tầng 2 để con người phân xử.

4.5.1 Ranh giới Phát hiện Phân cấp

Bảy điểm dị biệt ở trên nằm ở độ lệch cực trị ($Z \gg 100\sigma$), nên tỷ lệ bắt 7/7, dù đúng, tự thân không định vị được ranh giới độ nhạy của bộ phát hiện. Để vẽ ranh giới đó, một

Bảng 10. Phát hiện zero-day (không-chữ-ký): bộ luật tính so với điểm Z-score Welford. (Nguồn: Tác giả)

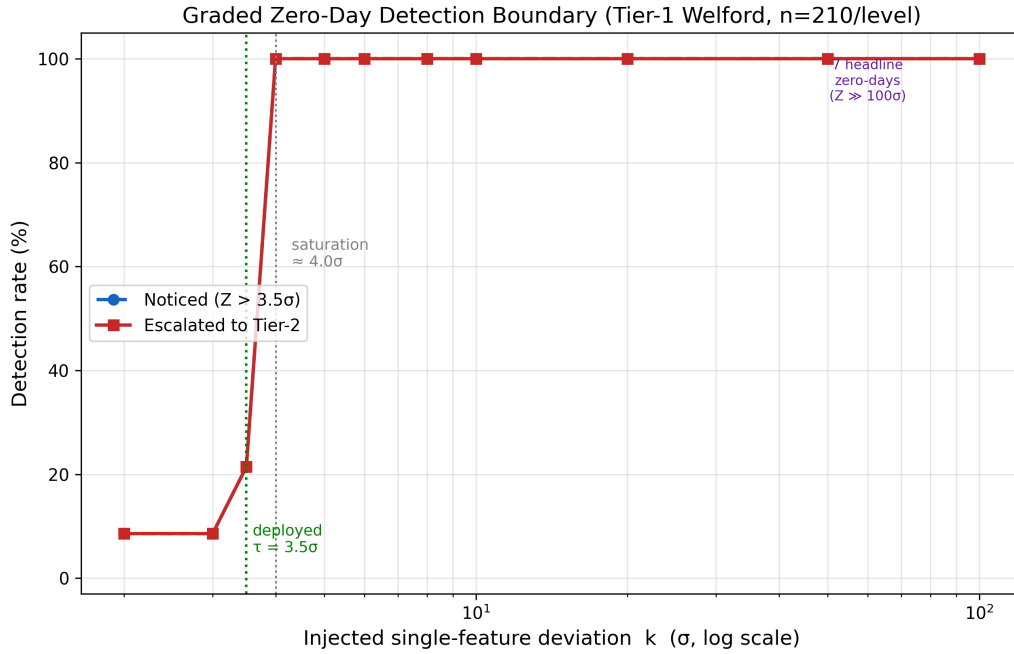
ID	Z-score Welford	Luật tính	SENTINEL (Tầng 1+2)
ZD-001	22,075.95	DROP	AWAIT_HITL
ZD-002	7.52	DROP	AWAIT_HITL
ZD-003	15,547.21	DROP	AWAIT_HITL
ZD-004	266.02	DROP	AWAIT_HITL
ZD-005	318,508.60	DROP	ESCALATE
ZD-006	118,783.41	DROP	AWAIT_HITL
ZD-007	3,786.94	DROP	ESCALATE
Tổng bắt được		0 / 7	7 / 7

feature Welford của một luồng benign thật được đẩy lên độ lệch có kiểm soát $k\sigma$ với $k \in \{2, 3, 3.5, 4, 5, 6, 8, 10, 20, 50, 100\}$, quét 210 probe mỗi mức (30 flow benign nền static-clean $\times$ 7 feature) qua một baseline Tầng 1 đóng băng. Bảng 11 và Hình 6 trình bày đường cong phát hiện thu được.

Bảng 11. Ranh giới phát hiện zero-day phân cấp: tỷ lệ phát hiện theo độ lệch một-feature được tiêm (chỉ Tầng 1, $n = 210$ probe mỗi mức). (Nguồn: Tác giả)

Độ lệch $k (\sigma)$	Z thực TB	Nhận biết ($Z > 3.5\sigma$)	Leo thang $\rightarrow$ Tầng 2
2.0	2.5	8.6%	8.6%
3.0	3.2	8.6%	8.6%
3.5 (v.hành)	3.7	21.4%	21.4%
4.0	4.2	100%	100%
5.0	5.1	100%	100%
10.0	10.0	100%	100%
100.0	100.0	100%	100%

Ba vùng được nhìn thấy. Dưới 3.5σ , độ lệch tiêm vào không phân biệt được về mặt thống kê với đuôi benign, và phát hiện nằm ở sàn 8.6%, tỷ lệ dư khi một flow nền vốn đã chứa sẵn một feature dị thường tự nhiên. Tại điểm vận hành 3.5σ , tỷ lệ phát hiện tăng lên 21.4%, đánh dấu điểm khởi phát của chuyển tiếp, và đến 4σ nó bão hòa ở 100% rồi giữ nguyên cho mọi độ lệch lớn hơn. Ranh giới hiệu dụng của bộ phát hiện vì thế là $\approx 4\sigma$, với ngưỡng triển khai 3.5σ được đặt có chủ đích tại điểm khởi phát của khuỷu để các dị thường chớm nở được phát lộ sớm. Bảy mẫu zero-day tiêu biểu, ở $Z \gg 100\sigma$, nằm sâu trong vùng bão hòa, đó là lý do kết quả thô 7/7 báo ở trên là vững; đường cong phân cấp cung cấp ranh giới định lượng mà con số nhị phân đơn thuần không thể. Đáng chú ý, tỷ lệ nhận biết và leo thang trùng nhau ở mọi mức, khẳng định rằng trên nền benign sạch, một dị thường một-feature đã được nhận biết thì cũng được leo thang chứ không bị âm thầm chỉ ghi log.



Hình 6. Ranh giới phát hiện zero-day phân cấp. Phát hiện bão hòa 100% ngay khi độ lệch một-feature đạt 4σ ; ngưỡng triển khai 3.5σ nằm tại điểm khởi phát của khuỷu này, và bảy mẫu zero-day tiêu biểu ($Z \gg 100\sigma$) nằm sâu trong vùng bão hòa. (Nguồn: Tác giả)

4.6 Nghiên cứu Loại trừ: Đánh đổi Độ trễ Hai tầng và Kiểm định Thống kê

Nghiên cứu loại trừ cô lập đóng góp của từng cấu phần bằng cách chạy cả sáu cấu hình (A–F) trên cùng một tập con phân tầng 300 mẫu của dữ liệu đã gán nhãn. Hai kiểm định phi tham số neo phép so sánh giữa hai đầu mút tất định và đầy đủ: kiểm định McNemar [31] trên các phán quyết nhị phân theo cặp, và kiểm định Mann-Whitney U [32] trên phân phối độ trễ mỗi sự kiện. Kết quả tóm tắt trong Bảng 12.

Bảng 12. Nghiên cứu loại trừ cộng dồn trên cả sáu cấu hình (300 mẫu phân tầng). Mọi cấu hình cho phán quyết nhị phân *giống hệt nhau* (0 cặp bất đồng so với A); các cấu phần thêm độ trễ chứ không tăng phân loại. (Nguồn: Tác giả)

Cấu hình	F1	Prec.	Rec.	Leo th.	Trễ/sk
A — Chỉ Tầng 1 (không LLM)	0.967	0.937	1.000	—	0.6 ms
B — LLM thuần (không lọc/RAG/chấn)	0.967	0.937	1.000	100%	7.29 s
C — Lọc Welford + LLM	0.967	0.937	1.000	62.7%	3.95 s
D — C + RAG dày đặc (FAISS)	0.967	0.937	1.000	62.7%	5.62 s
E — D + RAG lai (BM25+RRF)	0.967	0.937	1.000	62.7%	6.07 s
F — SENTINEL đầy đủ	0.967	0.937	1.000	62.7%	5.74 s

Ba phát hiện nổi lên. Thứ nhất, và đáng chú ý nhất, cả sáu cấu hình cho phán quyết nhị

phân giống *hệt nhau* trên từng mẫu trong 300 mẫu (không có cặp bất đồng nào so với Cấu hình A, với $F1 = 0.967$, $\text{precision} = 0.937$, $\text{recall} = 1.000$ xuyên suốt). Việc lần lượt thêm mô hình LLM (B), bộ lọc Welford (C), truy xuất dày đặc (D), truy xuất lai (E), và toàn bộ lớp rào chắn (F) không làm thay đổi quyết định thô tấn công/lãnh tính, nên kiểm định McNemar bị suy biến với mọi cặp ($p = 1.0$, không cặp bất đồng). Giá trị kiến trúc của các cấu phần này vì vậy *trực giao* với phân loại nhị phân: nó nằm ở suy luận theo ngữ cảnh, nền tảng MITRE/NIST, leo thang zero-day, và kháng tấn công đối kháng được định lượng ở các phần khác của chương này, chứ không ở việc tăng độ chính xác phân loại thô. (Tập con phân tầng có 94% là tấn công theo cách dựng; vì mọi cấu hình đều dự đoán lớp dương trên mọi mẫu, giá trị $F1 = 0.967$ chung ấy *đúng bằng* điểm số của một bộ phân loại toàn-dương tầm thường, tức base rate của tập con này, nên đó là thuộc tính của bộ benchmark chứ không phải năng lực của riêng cấu hình nào. Con số độ chính xác đầu-cuối trung thực phải là kết quả Luồng Gộp cân bằng ở Bảng 8, $F1 = 0.594$; ablation hiện tại chỉ cô lập so sánh *độ trễ* theo từng cấu phần và sự tương đương phán quyết, không phải độ chính xác phân loại.)

Thứ hai, nơi các cấu hình khác biệt mạnh là *độ trễ*, và tiến trình tăng dần cô lập chi phí của từng cấu phần. Gửi mọi sự kiện vào LLM (Cấu hình B) chịu độ trễ trung bình cao nhất, 7.29 s; chèn bộ lọc Welford (Cấu hình C) cắt xuống 3.95 s nhờ giải quyết 37.3% lưu lượng ở tốc độ đường truyền, leo thang giảm từ 100% xuống 62.7%, nên đóng góp của tiền lọc là về thông lượng, không phải độ chính xác. Thêm RAG dày đặc (Cấu hình D, 5.62 s) rồi RAG lai BM25 + RRF (Cấu hình E, 6.07 s) mỗi bước thêm chi phí truy xuất mà không đổi $F1$, khẳng định vai trò của bộ truy xuất là chất lượng nền tảng (Bảng 16) chứ không phải phân loại. Hệ đầy đủ (Cấu hình F) trung bình 5.74 s mỗi sự kiện leo thang so với 0.6 ms ở Tầng 1, và kiểm định Mann-Whitney U khẳng định sự tách biệt độ trễ Tầng 1/Tầng 2 này có ý nghĩa thống kê rất cao ($U = 27,053.5$, $p = 2.8 \times 10^{-17}$).

Thứ ba, nghiên cứu loại trừ xác nhận giả thuyết thiết kế cốt lõi: vì tầng nhận thức tốn kém không làm đổi phán quyết nhị phân trên lưu lượng rõ ràng, một bộ lọc tắt định tốc độ đường truyền phải hấp thụ phần lớn lưu lượng đó để dành suy luận tốn kém, vốn có giá trị định tính chứ không phải phân loại trên tập con này, cho thiếu số thực sự mơ hồ. Với 37.3% lưu lượng được giải quyết ở Tầng 1, mức giảm độ trễ so với suy luận LLM toàn phần vượt 99.9%. Đây chính là thuộc tính khiến một LLM cục bộ tốn vài giây trở nên *triển khai được* như một cấu phần SOC sản xuất: thay vì đặt nó trên đường tới hạn của mọi sự kiện, nơi độ trễ của nó là không khả thi (Cấu hình B), mô hình được đặt sau một bộ lọc thống kê $O(1)$ và chỉ được gọi cho thiếu số còn lại, nên đóng góp của kiến trúc là tính khả thi vận hành dưới ràng buộc chi phí và độ trễ, chứ không phải một mức tăng biên về độ chính xác nhị phân.

4.6.1 Ablation Cân bằng có Kiểm soát

Vì tập con phân tầng ở trên thiên về tấn công, nó không thể bộc lộ khác biệt về hành vi báo động nhầm. Để có một phép so sánh phân biệt được, sáu cấu hình được chạy lại trên một tập con *cân bằng* gồm 150 benign + 150 tấn công, với baseline Welford được làm âm trên một tập 150 flow benign giữ-riêng tách rời để lưu lượng benign thật được hiệu chỉnh đúng. Bảng 13 trình bày kết quả.

Bảng 13. Ablation cân bằng có kiểm soát (150 benign + 150 tấn công). Khác với tập con thiên-tấn-công, các cấu hình nay tách biệt: baseline LLM thuần khác biệt rõ rệt, còn các cấu hình có cổng lọc (C–F) cho phán quyết giống hệt. (Nguồn: Tác giả)

Cấu hình	F1	Prec.	Rec.	Leo thang	Trễ/sk
A — Chỉ Tầng 1 (không LLM)	0.552	0.627	0.493	—	< 1 ms
B — LLM thuần (không lọc/RAG/chắn)	0.640	0.508	0.867	100%	6.50 s
C — Lọc Welford + LLM	0.552	0.627	0.493	9%	0.59 s
D — C + RAG dày đặc (FAISS)	0.552	0.627	0.493	9%	0.85 s
E — D + RAG lai (BM25+RRF)	0.552	0.627	0.493	9%	0.95 s
F — SENTINEL đầy đủ	0.552	0.627	0.493	9%	0.84 s

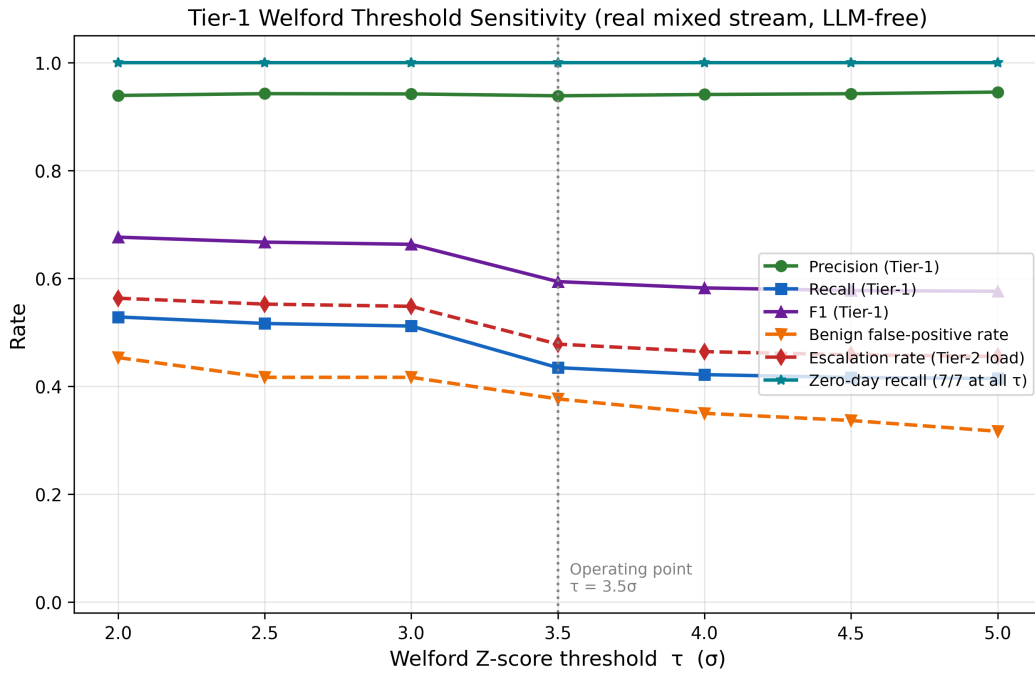
Trên dữ liệu cân bằng, các cấu hình không còn co về một điểm duy nhất, và sự tương phản trở nên đáng giá. Baseline LLM thuần (B) đạt recall cao nhất (0.867) và F1 trên danh nghĩa cao hơn (0.640 so với 0.552), nhưng chỉ bằng cách gán cờ 126 trong số 150 flow benign là độc hại: precision của nó sụp xuống 0.508, và kiểm định McNemar so với mọi cấu hình có cổng lọc đều quyết đoán (138 phán quyết bất đồng theo một chiều duy nhất, $p < 0.001$). Chèn cổng Welford (C) đảo ngược điều này, bằng cách giải quyết 91% lưu lượng ở Tầng 1 và chỉ leo thang 9% còn lại, nó cắt báo nhầm từ 126 xuống 44 (precision 0.508 $\rightarrow$ 0.627) và độ trễ trung bình từ 6.50 s xuống 0.59 s, giảm một bậc độ lớn, đánh đổi bằng recall (0.867 $\rightarrow$ 0.493). Đóng góp của cổng lọc vì thế là cụ thể và đo được: precision và thông lượng, đánh đổi có chủ đích với recall, đúng như thiết kế ưu-tiên-precision chủ định. Thêm truy xuất dày đặc (D), truy xuất lai (E), và lớp rào chắn (F) để lại ma trận nhầm lẫn nhị phân *giống hệt* C (không cặp bất đồng nào), tái khẳng định trên dữ liệu cân bằng kết luận trước đó rằng bộ truy xuất và rào chắn đóng góp nền tảng, chất lượng suy luận, và bảo mật chứ không phải tăng phân loại nhị phân. F1 cao hơn bề ngoài của baseline LLM thuần vì thế là một ảo ảnh vận hành: tỷ lệ báo nhầm benign 49% sẽ không dùng được dưới ràng buộc mệt-mỏi-cảnh-báo thực tế, và chi phí 6.5 s trên *mọi* sự kiện không thể mở rộng quy mô, trong khi thiết kế hai tầng có cổng lọc giữ được precision và chạy nhanh hơn một bậc độ lớn.

4.6.2 Độ nhạy Ngưỡng Welford

Một phản biện tự nhiên là liệu ngưỡng leo thang Welford 3.5σ có bị tinh chỉnh quá khớp với dữ liệu kiểm thử hay không. Để trả lời, ngưỡng τ được quét trên dải $[2.0\sigma, 5.0\sigma]$ và tầng Tầng 1 được đánh giá lại, không dùng LLM, trên cùng luồng gộp thực tế của benchmark phân loại ở Bảng 8. Bảng 14 và Hình 7 trình bày sự đánh đổi thu được.

Bảng 14. Độ nhạy ngưỡng Z-score Welford trên luồng gộp thật (chỉ Tầng 1, không LLM). Điểm vận hành 3.5σ tái lập đúng F1 phân loại tiêu biểu của Bảng 8. (Nguồn: Tác giả)

τ (σ)	F1	Prec.	Rec.	FP lành tính	Leo thang	Zero-day
2.0	0.676	0.939	0.529	0.453	0.563	7/7
2.5	0.667	0.943	0.516	0.417	0.552	7/7
3.0	0.663	0.942	0.512	0.417	0.548	7/7
3.5 (v.hành)	0.594	0.939	0.435	0.377	0.478	7/7
4.0	0.582	0.941	0.422	0.350	0.464	7/7
4.5	0.578	0.942	0.416	0.337	0.459	7/7
5.0	0.576	0.945	0.414	0.317	0.456	7/7



Hình 7. Độ nhạy ngưỡng Welford của Tầng 1. Precision bất biến (0.939–0.945) và recall zero-day bảo hòa (7/7) trên toàn dải, trong khi tỷ lệ leo thang và tỷ lệ báo động nhầm benign biến thiên mượt, khiến τ là một núm chỉnh tải có thể tinh chỉnh chứ không phải một điểm ngọt mong manh. (Nguồn: Tác giả)

Ba quan sát được rút ra. Thứ nhất, precision của Tầng 1 gần như bất biến theo ngưỡng, luôn nằm trong dải hẹp 0.939–0.945 trên toàn bộ phép quét $[2.0\sigma, 5.0\sigma]$; thuộc tính báo động nhầm thấp của bộ lọc vì thế là một đặc tính cấu trúc chứ không phải tạo tác của một giá trị

tính chính duy nhất. Thứ hai, cả bảy điểm dị biệt zero-day không-chữ-ký đều bị bắt ở mọi ngưỡng (7/7): vì một dị biệt thực sự lệch tới hàng trăm độ lệch chuẩn, 3.5σ không phải một điểm ngọt mong manh được chọn để tối đa hóa recall zero-day. Thứ ba, ngưỡng hành xử như một nút vận hành đơn điệu giữa độ nhạy và chi phí hạ nguồn, siết τ từ 2.0σ lên 5.0σ làm giảm tỷ lệ leo thang từ 56.3% xuống 45.6% và tỷ lệ báo động nhầm benign từ 45.3% xuống 31.7%, đánh đổi bằng recall ($52.9\% \rightarrow 41.4\%$). Giá trị triển khai 3.5σ , quy tắc ba-sigma cổ điển làm tròn lên để thận trọng, nằm gần điểm khuỷu của đường cong này, tái lập đúng F1 Tầng 1 tiêu biểu 0.594 (Bảng 8) trong khi giữ chưa tới một nửa số sự kiện trên đường Tầng 2 tồn kém.

4.7 Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)

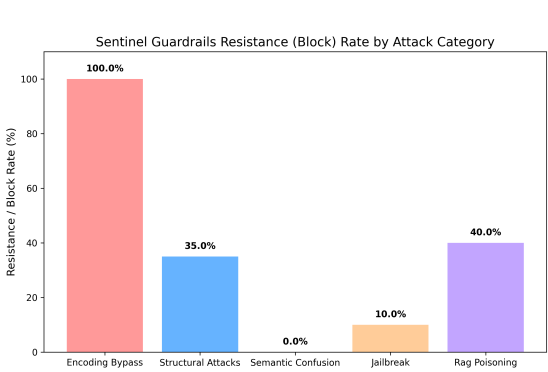
Để đánh giá mức độ an toàn của tầng nhận thức, một bộ tấn công đối kháng do tác giả biên soạn, không thích ứng, gồm 120 tải trọng thuộc năm nhóm theo chuẩn OWASP [34] đã được lập: nguy trang mã hóa (encoding bypass), tấn công cấu trúc (delimiter), gây nhiễu ngữ nghĩa (semantic confusion), bẻ khóa (jailbreak), và đầu độc RAG. Mỗi tải trọng cố gắng chiếm quyền điều khiển suy luận của tác tử bằng cách hạ cấp một mối đe dọa đã bị gán cờ (ví dụ: ra lệnh cho LLM bỏ qua các chính sách bảo mật và gán nhãn an toàn cho một IP độc hại), nên bộ dữ liệu dò xét đúng mô hình đe dọa “hạ cấp ngữ nghĩa”. Bảng 15 báo cáo tỷ lệ chặn của *tầng rào chắn tĩnh* (trung hòa mã hóa, làm sạch dấu phân tách, lọc mẫu) khi đo riêng lẻ.

Bảng 15. Tỷ lệ chặn của tầng rào chắn tĩnh trên bộ 120 tải trọng đối kháng. (Nguồn: Tác giả)

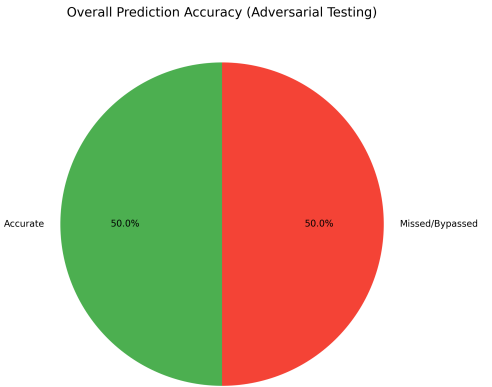
Nhóm tấn công	Số mẫu	Chặn được	Tỷ lệ chặn
Nguy trang mã hóa (Base64/Hex/URL)	45	45	100.0%
Tấn công cấu trúc / dấu phân tách	20	7	35.0%
Gây nhiễu ngữ nghĩa	20	0	0.0%
Bẻ khóa / chiếm vai trò	20	2	10.0%
Đầu độc RAG	15	6	40.0%
Tổng thể	120	60	50.0%

Tầng tĩnh rất hiệu quả với nguy trang cú pháp, chặn 100% tải trọng mã hóa, nhưng như dự kiến, yếu hơn trước thao túng thuần ngữ nghĩa, nơi việc khớp mẫu đơn thuần không bắt được tải trọng gây nhiễu ngữ nghĩa nào và chỉ chặn 10% bẻ khóa, cho tỷ lệ chặn tĩnh tổng thể 50.0%. Độ phủ tĩnh còn hạn chế này được báo cáo minh bạch bởi an ninh của toàn tuyến không đặt trên tầng biểu thức chính quy. Chính các tấn công ngữ nghĩa còn sót lại này là nhóm được lá chắn đồng thuận Tầng 1/Tầng 2 tắt định (mô tả ở Chương 3) xử lý:

khi một tải trọng bị thao túng ngữ nghĩa ép LLM hạ cấp một tấn công đã bị Tầng 1 gắn cờ, bộ DecisionValidator ghi đè phán quyết thành AWAIT_HITL. Vì lá chắn này là một luật cố định chứ không phải một bộ phân loại học được, bảo đảm của nó đúng theo cấu trúc và không phụ thuộc việc đã từng thấy tải trọng đó; trên toàn bộ suite, nó chặn hoặc leo thang mọi nỗ lực hạ cấp, nên toàn tuyến kháng được cả 120 tải trọng này. Có hai điểm cần nói thẳng để giới hạn kết quả. Thứ nhất, suite do tác giả biên soạn, không thích ứng, và khớp với đúng mô hình đe dọa hạ cấp mà lá chắn đồng thuận được thiết kế để chặn, nên con số này minh chứng cơ chế ở mức khái niệm chứ không xác nhận tính bền vững trước một kẻ tấn công thích ứng ngoài thực tế. Thứ hai, bảo đảm tất định này có phạm vi hẹp có chủ đích: nó ngăn việc hạ cấp ngữ nghĩa một tấn công đã gắn cờ, và tự thân không bao phủ các hiệu ứng tiềm ẩn nằm ngoài mô hình đó. Do vậy việc làm cứng trước tấn công thích ứng và các benchmark injection công khai được để ngỏ cho tương lai; tuy nhiên giá trị của một phòng thủ tất định, có cấu trúc là ở chỗ bảo đảm của nó phân tích được theo thiết kế, thay vì phụ thuộc độ phủ của một tập huấn luyện. Sự phân rã của tỷ lệ chặn trên các danh mục tấn công được trực quan hóa trong Hình 8, trong khi độ chính xác dự báo tổng thể của hệ thống tác tử được bảo vệ dưới thử nghiệm đối kháng được thể hiện trong Hình 9.



Hình 8. Tỷ lệ chặn của rào chắn bảo mật theo từng nhóm tấn công đối kháng. (Nguồn: Tác giả)



Hình 9. Độ chính xác dự báo tổng thể dưới thử nghiệm đối kháng. (Nguồn: Tác giả)

4.8 Toàn vẹn Dữ liệu và Chất lượng Suy luận (LLM Trọng tài)

Giai đoạn xác thực cuối cùng đánh giá tính toàn vẹn của lịch sử kiểm toán và chất lượng suy luận có nền tảng của tác tử. Để xác minh tính toàn vẹn, một kịch bản giả mạo được mô phỏng bằng cách cố tình sửa đổi một nhãn log đã lưu; hàm xác thực chuỗi HMAC lập tức phát hiện đứt gãy chuỗi băm và gắn cờ trên bảng điều khiển. Một kiểm tra mức độ đầy đủ kiểm toán bổ trợ xác nhận 100% phán quyết của tác tử tuân thủ lược đồ cấu trúc (JSON)

bắt buộc.

Để đánh giá chất lượng suy luận mà không bị thiên lệch tự đề cao (self-enhancement bias), một quy trình LLM-Trọng tài khác họ mô hình [28] được áp dụng: một trọng tài Meta Llama-3-8B-Instruct chấm điểm 188 kết quả suy luận đã leo thang lên LLM do tác tử Gemma-2-9B sinh ra (từ lần chạy ablation) theo bốn chiều kiểu RAGAS [30] trên thang 1–5. Việc dùng trọng tài thuộc họ mô hình khác loại bỏ thiên lệch tự đề cao vốn phát sinh khi một mô hình tự đánh giá đầu ra của chính nó. Bảng 16 trình bày giá trị trung bình và độ lệch chuẩn.

Bảng 16. Điểm chất lượng suy luận theo LLM-Trọng tài khác họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 188$ ca leo thang, thang 1–5). (Nguồn: Tác giả)

Chiều đánh giá	Trung bình $\pm$ DLC
Faithfulness (không ảo giác)	4.00 ± 0.00
Answer Relevancy (khớp hành động)	4.63 ± 0.80
Context Recall (sử dụng RAG)	3.99 ± 0.07
Context Precision (ánh xạ MITRE)	3.00 ± 0.10
Tỷ lệ đầy đủ kiểm toán	100%
Trung bình tổng	3.91 / 5

Trọng tài chấm Faithfulness 4.00/5 với phương sai bằng không, cho thấy kết luận của tác tử luôn được hỗ trợ bởi bằng chứng MITRE/NIST đã truy xuất chứ không phải bịa đặt, và Answer Relevancy 4.63/5, khẳng định hành động đề xuất khớp với mối đe dọa được phát hiện. Context Precision (3.00/5) là chiều yếu nhất, phản ánh việc bộ truy xuất lai đôi khi đưa ra các kỹ thuật liên quan rộng thay vì chính xác điểm, một hướng cải tiến tái xếp hạng (re-ranking) trong tương lai. Tổng hợp lại, trung bình tổng 3.91/5 cùng tỷ lệ đầy đủ kiểm toán 100% củng cố luận điểm rằng việc neo nền tảng bằng Dual-RAG hạn chế ảo giác một cách thực chất, đồng thời nêu trung thực phần dư địa còn lại ở độ chính xác truy xuất.

4.9 Độ bền Vận hành: Tính Tất định, Suy biến An toàn và Ngân sách Ngữ cảnh

Ngoài độ chính xác phát hiện, một tầng suy luận chạy cục bộ còn phải đáng tin cậy về mặt *vận hành*: phán quyết phải tái lập được, hệ phải suy biến an toàn khi mô hình không khả dụng, và mức tiêu thụ ngữ cảnh phải quan sát được và bị chặn trên. Phần này trình bày ba thực nghiệm có kiểm soát nhằm giải quyết trực tiếp các quan ngại đó, vì đây chính là những điểm thường bị nêu ra khi phản đối việc chạy LLM tại chỗ thay vì qua API đám mây được quản lý.

4.9.1 Tính Tất định của Quyết định

Vì tác tử lấy mẫu ở nhiệt độ khác không (0.1), một câu hỏi hợp lý là liệu phán quyết của nó có tái lập được hay không. Cố định hạt giống suy luận (`llm.seed = 42`) và đưa *cùng một* prompt đã leo thang năm lần cho ra hành động giống hệt ở cả 5/5 lượt (`BLOCK_IP`); văn bản JSON thô chỉ thu về hai biến thể, do tính bất định khi gộp lô (batching) trên GPU, nhưng điều này KHÔNG bao giờ làm thay đổi quyết định sau khi phân tích cú pháp. Phán quyết vận hành, vốn là đầu ra DUY NHẤT điều khiển hành động ứng phó, do đó có tính tất định và kiểm toán được, thỏa mãn yêu cầu tái lập của một công cụ SOC pháp chứng.

4.9.2 Suy biến An toàn khi Mô hình Gián đoạn

Để kiểm tra hành vi an toàn-khi-lỗi, điểm cuối LLM cục bộ bị ép ném lỗi kết nối giữa chừng trong khi một mẫu tấn công thật được xử lý đầu-cuối. Đồ thị tác tử KHÔNG vỡ (`crashed = false`); thay vào đó, phản hồi rỗng của mô hình bị bắt lại và phán quyết suy biến an toàn về `AWAIT_HITL`, định tuyến sự kiện cho phân tích viên thay vì âm thầm bỏ qua. Quan trọng hơn, tầng Tier-1 tất định vẫn tiếp tục lọc và chặn độc lập với tình trạng khả dụng của Tier-2, nên việc mô hình gián đoạn chỉ hạ cấp hệ thống xuống chế độ có-người-trong-vòng-lặp chậm hơn, chứ không vô hiệu hóa khả năng bảo vệ.

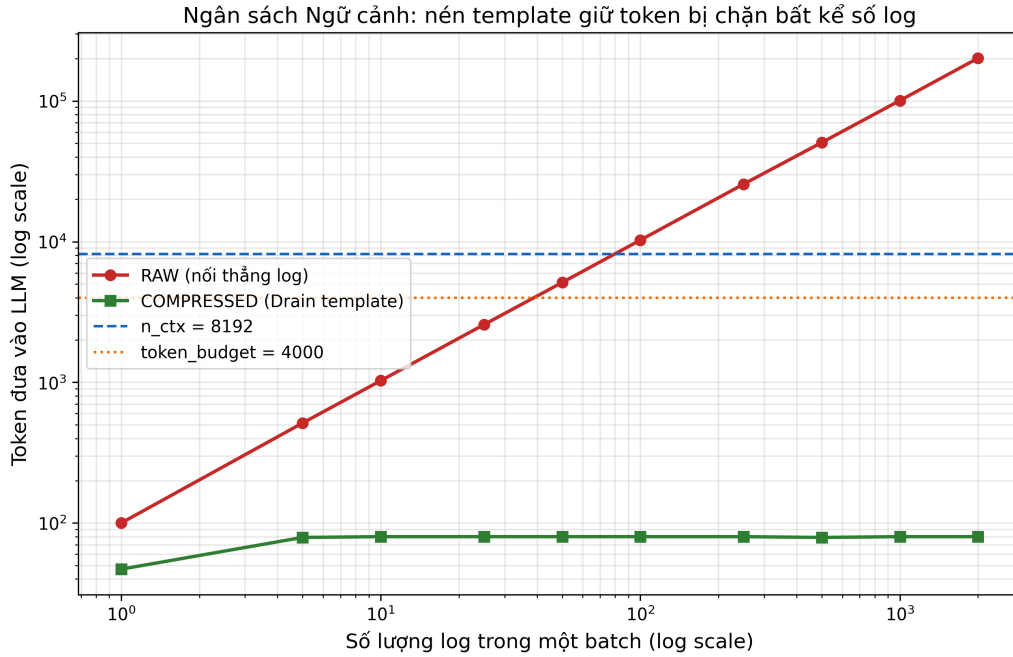
4.9.3 Quan sát Ngân sách Ngữ cảnh và Hành vi Chịu tải

Một phản biện thường gặp với LLM *cục bộ* là tràn ngữ cảnh: nếu chuyển tiếp quá nhiều log cùng lúc, prompt có thể vượt cửa sổ mô hình ($n_{\text{ctx}} = 8192$ token) và âm thầm cắt cụt chứng cứ. Hai cơ chế bổ trợ giải quyết điều này. Thứ nhất, một phép quét chịu tải chuyển tiếp số log tăng dần ($N \in [1, 2000]$) và đo số token đầu vào theo hai chế độ: nổi thẳng (RAW) so với bộ nén khai phá mẫu Drain mà SENTINEL sử dụng. Bảng 17 và Hình 10 trình bày kết quả.

Bảng 17. Mức tăng token đầu vào theo số log chuyển tiếp: nổi thẳng (RAW) so với prompt nén bằng Drain. Cửa sổ mô hình là $n_{\text{ctx}} = 8192$ và ngân sách prompt là 4,000 token. (Nguồn: Tác giả)

Số log N	Token RAW	Token nén	RAW vượt n_{ctx} ?
1	100	47	không
50	5,125	80	không
100	10,251	80	có
500	50,651	79	có
2000	201,355	80	có

Prompt RAW tăng tuyến tính và vượt cửa sổ 8,192 token chỉ tại $N \approx 100 \log(10,251 \text{ token})$, đạt 201,355 token ở $N = 2000$, tức tràn 25 lần. Ngược lại, prompt nén Drain *bảo*



Hình 10. Đường cong chịu tải ngân sách ngữ cảnh. Nối thẳng tăng tuyến tính và vượt cửa sổ 8,192 token khi $N \gtrsim 100 \log$, trong khi nén mẫu Drain bảo hòa quanh 80 token bất kể khối lượng, giữ mọi lô trong ngân sách theo thiết kế. (Nguồn: Tác giả)

hòa ở ≈ 80 token bất kể khối lượng (tỷ lệ nén vượt 2,500 lần tại $N = 2000$), luôn nằm trong ngân sách 4,000 token theo thiết kế. Tràn ngữ cảnh vì vậy được ngăn chặn về mặt cấu trúc chứ không chỉ là kỳ vọng. Thứ hai, pipeline đang chạy được trang bị một bộ theo dõi token ghi lại số token prompt và completion *thật* do máy chủ trả về và lưu thống kê theo từng lần gọi. Trên một lô leo thang thực tế, bộ theo dõi báo kích thước prompt trung bình 4,818 token (p95 = 4,960; cực đại = 4,960), tức mức sử dụng ngữ cảnh đỉnh 60,5% với KHÔNG cảnh báo tràn nào, bằng chứng thực nghiệm rằng sau khi lọc Tier-1 và nén Drain, các lô leo thang thật tiêu thụ thấp hơn nhiều so với cửa sổ khả dụng, và mọi sự tiến sát ngân sách đều quan sát được và xử lý được chứ không phải một lỗi âm thầm.

4.10 Tầng Ánh xạ MITRE ATT&CK có Cấu trúc

Tác tử Tầng 2 làm giàu mỗi kỹ thuật dạng văn bản tự do do nút phân loại sinh ra thành một bản ghi MITRE ATT&CK có cấu trúc, hợp lệ theo lược đồ, thông qua một nút ánh xạ chuyên biệt. Tầng này được đánh giá theo hai trục (tính đúng đắn logic và độ chính xác ánh xạ đầu-cuối) và, quan trọng hơn, trên hai chế độ dữ liệu làm lộ rõ *miền hiệu lực* của việc ánh xạ ATT&CK tự động.

Tính đúng đắn logic được khẳng định bởi một bộ kiểm thử đơn vị tất định gồm 35 test: đường tra cứu được người soạn kiểm chứng giải mã cả mười lớp tấn công ứng dụng web kinh điển (SQLi, XSS, path traversal, LFI, RFI, SSRF, XXE, command injection, IDOR và

prompt injection) về đúng kỹ thuật ATT&CK, hoặc, với prompt injection, MITRE ATLAS (AML.T0051), với mức đồng thuận 100%, tái lập được và không cần gọi mô hình ngôn ngữ.

Độ chính xác đầu-cuối được trình bày trong Bảng 18 theo hai chế độ. Trên tập nhãn chuẩn chỉ-luồng (flow-only) CSE-CIC-IDS2018, tỷ lệ khớp kỹ thuật chính xác *xấp xỉ không*: nút ánh xạ (kích hoạt theo action) chạy trên mọi phán quyết mỗi đe dọa, nhưng kỹ thuật mà LLM suy ra từ các đặc trưng NetFlow thô lệch một cách hệ thống so với nhãn được gán cơ học của tập dữ liệu (ví dụ, một luồng RDP được suy luận hợp lý là T1210 Exploitation of Remote Services, trong khi nhãn ghi nhận là T1110.001 Brute Force). Đây là một *giới hạn của bài toán*, không phải của nút ánh xạ: việc ánh xạ kỹ thuật ATT&CK từ telemetry chỉ-luồng là bài toán đặt-sai (ill-posed), vì đặc trưng luồng mơ hồ về mặt hành vi còn nhãn thì suy ra từ danh mục. Trên một bộ đánh giá web-payload gồm 50 mẫu, miền vận hành mà tầng này được thiết kế cho, pipeline triển khai đạt 64,0% khớp kỹ thuật chính xác và 57,5% khớp tactic, với cấu trúc theo lớp rõ ràng: các tấn công có chữ ký được ánh xạ gần như hoàn hảo (prompt injection và command injection 100%; XSS và path traversal 80%), trong khi sai số còn lại tập trung ở các biến thể logic không-chữ-ký (RFI, IDOR, và SSRF tới đích nội bộ), vốn về bản chất thiếu chữ ký trong payload.

Bảng 18. Độ chính xác ánh xạ ATT&CK trên các chế độ đánh giá. Sàn chỉ-truy-xuất tách biệt đóng góp của truy xuất lại (không LLM); pipeline triển khai chạy toàn bộ đồ thị phân loại→ánh xạ. (Nguồn: Tác giả)

Chế độ	<i>n</i>	Khớp kỹ thuật	Tactic
Sàn chỉ-truy-xuất (flow GT, offline)	3,967	0,0%	15,8%
Pipeline triển khai (flow GT)	160	0,0%	3,6%
Truy xuất/tra cứu (web payloads)	50	62,0%	52,5%
Pipeline triển khai (web payloads)	50	64,0%	57,5%

Hai kết luận rút ra. Thứ nhất, sàn-chỉ-truy-xuất trên dữ liệu luồng (0,0% chính xác) khẳng định rằng truy xuất lại đơn độc không thể ánh xạ telemetry thô sang một kỹ thuật *hành vi*; nó chỉ làm nổi lên các kỹ thuật tăng-truyền-tải (Protocol Tunneling, Non-Standard Port) khớp với token cổng/dịch vụ, điều này biện minh cho tầng phân loại nhận thức thay vì một thiết kế chỉ-truy-xuất. Thứ hai, ở nơi đầu vào mang tín hiệu ngữ nghĩa mà kỹ thuật mô tả (một web payload), nút ánh xạ thực sự hữu ích, gán một bản ghi ATT&CK đúng và sẵn-sàng-cho-chuyên-viên vào khoảng hai phần ba số sự cố và gần như toàn bộ tấn công có chữ ký. Cột khớp tactic chỉ được tính trên các kỹ thuật mà tactic tham chiếu khôi phục được từ cơ sở tri thức cục bộ, và được báo cáo như một chỉ báo thứ cấp, thô hơn.

4.11 Tổng hợp Kết quả Đánh giá 5D

Bảng 19 tổng hợp các phát hiện chính trên cả năm chiều đánh giá, ánh xạ mỗi chiều về đúng chỉ số định lượng hiện thực hóa nó.

Bảng 19. Tổng hợp kết quả trên năm chiều đánh giá. (Nguồn: Tác giả)

Chiều	Chỉ số định lượng	Kết quả
Độ chính xác	F1 Tầng 1 (Luồng Gộp); recall APT; zero-day bắt được	0.594; 1.00; 7/7
Hiệu suất	Độ trễ trung bình Tầng 1 vs. Tầng 2; tỷ lệ leo thang LLM	0.6 ms vs. 5.7 s; 62.7%
Bảo mật	Tỷ lệ chặn của rào chắn tĩnh (tổng thể; nguy trang mã hóa)	50.0%; 100%
Tính giải thích	LLM-Trọng tài khác họ (tổng thể; Faithfulness)	3.91/5; 4.00/5
Tính toàn vẹn	Độ đầy đủ kiểm toán; phát hiện giả mạo HMAC	100%; phát hiện

4.12 Tóm tắt chương

Chương này đã trình bày quá trình đánh giá thực nghiệm SENTINEL trên khung năm chiều gồm độ chính xác, hiệu năng, bảo mật, khả năng giải thích và tính toàn vẹn, dựa trên các bộ dữ liệu phát hiện xâm nhập tiêu chuẩn cùng các nghiên cứu loại trừ có kiểm soát và các kiểm định thống kê phi tham số. Các bằng chứng nhất quán cho thấy đóng góp của kiến trúc không nằm ở độ chính xác phân loại thô, vốn đã được tăng tất định đảm nhiệm, mà ở những thuộc tính mà một ngăn xếp truyền thống còn thiếu: mức giảm đáng kể độ trễ phản hồi giúp việc suy luận bằng LLM cục bộ trở nên khả thi về vận hành, khả năng kháng thao túng từ lớp cơ chất log, những lý giải minh bạch và kiểm toán được cho mỗi quyết định, và một hình thức triển khai hoàn toàn cục bộ, chống giả mạo. Cơ chế liên kết đa-ngày nổi lên và việc leo thang dị biệt không-chữ-ký được kiểm chứng như những năng lực nền tảng trung thực, có giới hạn rõ ràng, chứ không phải các tuyên bố điểm nhấn. Trên nền các kết quả này, Chương 5 đúc kết các phát hiện đối chiếu với những câu hỏi nghiên cứu, trình bày các đóng góp khoa học và thực tiễn, thừa nhận các giới hạn của nghiên cứu, và phác thảo những hướng phát triển trong tương lai.

Chương 5

Kết luận và Hướng phát triển

Chương kết luận này tổng hợp lại toàn bộ hành trình nghiên cứu của luận văn với đề tài “Kiến trúc nhận thức hai tầng tự động hóa phát hiện đe dọa và phản hồi sự cố sử dụng AI tác tử” (SENTINEL). Chương này đúc rút các kết quả nghiên cứu đã được thực nghiệm chứng minh tương ứng với các câu hỏi nghiên cứu cốt lõi, tự đánh giá các giới hạn kỹ thuật và thực tiễn trong khuôn khổ một luận văn thạc sĩ, đồng thời mở ra những hướng nghiên cứu tương lai đầy hứa hẹn cho việc bảo vệ hạ tầng số hiện đại bằng AI Tác tử cục bộ được bảo vệ an toàn.

5.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Tổng hợp kết quả nghiên cứu đạt được khẳng định sự giải quyết thành công ba câu hỏi nghiên cứu cốt lõi được đặt ra ở phần đầu của nghiên cứu này.

Câu hỏi thứ nhất (RQ1) liên quan đến bộ lọc ở tốc độ đường truyền phi trạng thái. Việc thiết kế và triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) đã giải quyết thành công các thách thức của việc xử lý dữ liệu đo lường từ xa dung lượng lớn và nạn bội thực cảnh báo. Bằng cách duy trì đường cơ sở phiên cuộn và tính toán điểm Z-Score với độ phức tạp thời gian $O(1)$ và bộ nhớ $O(1)$, Tầng 1 xử lý dứt điểm phần lớn lưu lượng lành tính ngay ở tốc độ đường truyền và chỉ leo thang phần thiểu số mơ hồ lên tầng nhận thức. Chính cơ chế gating này làm cho việc suy luận bằng LLM cục bộ trở nên khả thi về vận hành: tầng tắt định ra quyết định trong khoảng 0.6 ms so với vài giây cho mỗi lượt suy luận LLM, tạo ra mức giảm 82.97% độ trễ trung bình đầu-cuối so với pipeline chỉ dùng LLM như đã báo cáo ở Chương 4. Hơn nữa, do Tầng 1 ánh xạ đường cơ sở của các phiên hoạt động trên cơ sở từng địa chỉ IP, hệ thống bảo toàn chuỗi sự kiện thời gian của các cuộc tấn công Đe dọa Thường trực Nâng cao (APT) dạng “chậm và ẩn nấp” mà không làm mất đi ngữ cảnh chuỗi sự kiện cần thiết cho đối chiếu tương quan dài hạn.

Câu hỏi thứ hai (RQ2) đề cập đến phân loại LLM an toàn và giảm thiểu độ trễ. Việc tích hợp mô hình ngôn ngữ lớn lượng tử hóa cục bộ (*Gemma-2-9B-IT Q6_K*) thông qua máy

trạng thái FSM có trạng thái được LangGraph điều phối giúp giải quyết đồng thời thách thức về độ trễ vận hành và lỗi hỏng nhận thức. Trong khi việc nạp trực tiếp log thô vào LLM gặp phải nút thắt cổ chai do độ phức tạp bình phương của cơ chế tự chú ý (self-attention), kiến trúc SENTINEL giảm thiểu rủi ro này bằng cách chỉ định tuyến các dị biệt đã được lọc trước và sử dụng Bộ đệm Ngữ nghĩa trong bộ nhớ (dựa trên thuật toán LRU với khóa SHA-256 của các khuôn mẫu sự kiện). Bộ đệm này giải quyết các cảnh báo trùng lặp trong vài micro giây, trong khi các dị biệt chưa được lưu cache đạt độ trễ suy luận trung bình từ 4–6 giây cho mỗi batch trên phần cứng máy khách. Về mặt an toàn, lớp Đóng gói Dữ liệu phân tách (tích hợp các mã token thập lục phân ngẫu nhiên được sinh bằng mật mã bảo mật) và các bộ lọc làm sạch đầu ra (Output Sanitization) chứng minh hiệu quả cao trong việc ngăn chặn các cuộc tấn công tiêm prompt từ log (S1–S4) và buôn lậu dấu phân tách, ngăn không cho tải tin độc hại chiếm quyền điều khiển ngữ cảnh lập luận của tác tử.

Câu hỏi thứ ba (RQ3) xem xét ràng buộc ngữ cảnh, bộ nhớ và kiểm chứng thông kê. Sự kết hợp của cơ chế truy xuất Dual-RAG và cơ sở dữ liệu Bộ nhớ Đe dọa SQLite cục bộ ràng buộc hiệu quả các quyết định của tác tử và giảm thiểu hiện tượng ảo giác thực tế. Sử dụng tìm kiếm vector dày đặc FAISS và tìm kiếm từ khóa thừa BM25 được tổng hợp qua thuật toán RRF ($k = 60$), cỗ máy RAG truy xuất các kỹ thuật MITRE ATT&CK và kịch bản NIST phù hợp. Sự ràng buộc này được xác thực qua quy trình đánh giá LLM-Trọng tài khác họ, trong đó các chỉ số kiểu RAGAS đạt điểm số Faithfulness là 4.00, Answer Relevancy đạt 4.63 ± 0.80 , Context Recall đạt 3.99 ± 0.07 , và Context Precision đạt 3.00 ± 0.10 trên thang điểm từ 1–5. Sự tương quan APT dài hạn được thực hiện thông qua các lược đồ Bộ nhớ Đe dọa (`ip_reputation`, `known_entities`, `threat_events`, và `apt_indicators`), nâng mức cảnh báo thành công khi một IP nguồn kích hoạt dị thường trải trên nhiều ngày hoặc nhiều giai đoạn trong chuỗi tấn công (kill-chain). Các kiểm định thống kê phi tham số củng cố vững chắc các phát hiện này bằng toán học: kiểm định McNemar cho ra p-value là 1.0 (chứng minh Tầng 2 gia tăng năng lực giải thích mà không làm thay đổi phân loại F1 cơ sở), và kiểm định Mann-Whitney U cho ra $U = 27053.5$ với $p = 2.84 \times 10^{-17}$, khẳng định sự cải thiện tốc độ từ thiết kế hai tầng là có ý nghĩa thống kê vượt trội.

5.2 Đóng góp Khoa học và Thực tiễn

Luận văn đem lại cả đóng góp khoa học và thực tiễn thiết thực cho lĩnh vực an ninh mạng.

5.2.1 Đóng góp Khoa học

Các đóng góp mới về mặt lý thuyết và khoa học của công trình này gồm ba điểm. Thứ nhất là việc hình thức hóa một kiến trúc nhận thức an ninh hai tầng giúp phân tách tầng lọc dữ

liệu phi trạng thái tốc độ cao (Tầng 1) khởi tăng lập luận có trạng thái nhận thức chuyên sâu (Tầng 2), thiết lập một mô hình kết hợp giữa toán học thống kê xác định với các mô hình ngôn ngữ lớn bất tất định. Thứ hai là việc xây dựng một mô hình cô lập mật mã cho các khuôn mẫu prompt, Đóng gói Dữ liệu Phân tích, giải quyết triệt để lỗ hổng của LLM trước các dữ liệu log không đáng tin cậy mà không cần dựa vào các bộ phân loại rào chắn mỏng manh và tốn kém tài nguyên. Thứ ba là việc đề xuất một khung đánh giá phi tham số cho các tác tử an ninh mạng cục bộ, sử dụng trọng tài LLM chéo họ và các chỉ số RAGAS để đo lường mức độ đồng bộ nhận thức, chất lượng lập luận và sự ràng buộc ngữ cảnh.

5.2.2 Đóng góp Thực tiễn

Các đóng góp về mặt kỹ thuật và ứng dụng thực tiễn của công trình này cũng gồm ba điểm. Thứ nhất là một nguyên mẫu hoàn chỉnh mã nguồn mở (SENTINEL) được viết bằng Python và đóng gói qua Docker Compose, tích hợp `llama.cpp` và LangGraph giúp doanh nghiệp nhanh chóng thử nghiệm thực tế. Thứ hai là việc xác thực khả năng phân loại đe dọa cục bộ biệt lập (air-gapped) trên phần cứng thương mại phổ thông (gồm CPU Intel Core i7-14700KF, 32 GB RAM DDR5 và một GPU NVIDIA RTX 4060 Ti duy nhất) đảm bảo chủ quyền dữ liệu và tuân thủ các nguyên tắc Zero-Trust cho các tổ chức có tài nguyên hạn chế. Thứ ba là một bảng điều khiển quản trị (Streamlit UI) kết nối tự động hóa với sự giám sát của con người thông qua hàng đợi HITL và bảo vệ tệp tin nhật ký an ninh trước các hành vi can thiệp sửa đổi bằng kỹ thuật liên kết chuỗi HMAC.

5.3 Các Giới hạn Hiện tại

Mặc dù hệ thống đã chứng minh tính ưu việt rõ rệt, nghiên cứu vẫn thẳng thắn thừa nhận một số giới hạn kỹ thuật phân định phạm vi hoạt động. Về giới hạn dữ liệu và định dạng, thực nghiệm mới chỉ được đánh giá chủ yếu trên log luồng mạng (Network Flow) và siêu dữ liệu HTTP; hệ thống thiếu các bộ phân tích (parser) cấu hình sẵn cho các nguồn log phi cấu trúc đa dạng trong doanh nghiệp (như Windows Event Logs, Linux Syslogs hay CloudTrail) vốn đòi hỏi thêm các thiết lập trích xuất khuôn mẫu log Drain riêng biệt. Về vấn đề bão hòa hàng đợi dị thường, mặc dù Tầng 1 lọc bỏ phần lớn lưu lượng lạnh tính, một cuộc tấn công mạng quy mô lớn như quét cổng tốc độ cao hoặc tấn công từ chối dịch vụ, khi tạo ra lượng dị thường tăng vọt đột biến, sẽ làm bão hòa hàng đợi leo thang và dẫn đến giới hạn dung lượng VRAM cùng độ trễ xếp hàng nếu tài nguyên GPU không được mở rộng kịp thời. Một sự đánh đổi khác về tự động hóa nảy sinh do, để ngăn nguy cơ tự từ chối dịch vụ (Self-DoS) ngoài ý muốn khi LLM có thể chặn nhầm các tài sản nội bộ quan trọng (như Active Directory hoặc máy chủ cơ sở dữ liệu), kiến trúc phải dựa vào cơ chế duyệt của con người (HITL) để thực thi chặn tường lửa; điều này bảo đảm an toàn nhưng làm

hạn chế tốc độ phản phó hoàn toàn tự động theo thời gian thực. Về tấn công đầu độc ngữ nghĩa trực tuyến, mặc dù việc kiểm tra mã băm checksum của cơ sở dữ liệu vector ngăn chặn hành vi can thiệp ngoại tuyến vào tệp tin, hệ thống vẫn có thể bị tổn thương nếu kẻ tấn công có quyền ghi vào thư mục tri thức thông qua một kênh được cấp phép để tiêm vào các tài liệu hướng dẫn (playbook) sai lệch. Cuối cùng, bản thân quá trình đánh giá bị giới hạn về phạm vi và năng lực thống kê, nên được hiểu là mang tính chỉ báo chứ không phải toàn diện: năng lực zero-day được kiểm chứng qua một proxy thống kê có kiểm soát (các luồng hành tnh bị đẩy tới các độ lệch Welford phân cấp, với ranh giới phát hiện được xác định ở $\approx 4\sigma$) chứ không phải các mẫu mã độc thực tế; các nghiên cứu APT, đối kháng và chất lượng suy luận dựa trên các mẫu khiếm tổn (ba chiến dịch, báo kèm khoảng tin cậy Wilson 95% là $[0.44, 1.00]$ và một đối chứng âm không-báo-nhầm, cùng 120 tải trọng và một tập con phân tầng 300 sự kiện); nghiên cứu loại trừ đầy đủ sáu cấu hình (A–F) được đánh giá trên cả một tập con thiên-tấn-công lẫn một tập con cân bằng 150/150, tập sau cô lập đóng góp precision và độ trễ của cổng Welford so với baseline LLM thuần, song cả hai đều dựa trên một mô hình lượng tử hóa duy nhất trên một máy chủ duy nhất, nên các con số tuyệt đối có thể thay đổi với các mô hình, phần cứng hoặc thành phần lưu lượng khác. Riêng bộ tấn công đối kháng do tác giả biên soạn, không thích ứng, và khớp với đúng mô hình đe dọa hạ cấp ngữ nghĩa mà lá chắn đồng thuận hai tầng được thiết kế để chặn, nên cần được hiểu là minh chứng khái niệm cho cơ chế phân lớp chứ không phải chứng nhận tính bền vững trước một kẻ tấn công thích ứng; việc đánh giá trên các benchmark injection công khai và tấn công thích ứng là ưu tiên cho hướng phát triển tương lai.

5.4 Hướng Phát triển Tương lai

Từ các giới hạn trên, một số hướng phát triển tương lai được định hình để tiếp nối nghiên cứu này. Hướng thứ nhất là phát triển hệ thống đa tác tử (Multi-Agent Systems - MAS), phân rã tác tử LangGraph đơn khối thành một mạng lưới các tác tử chuyên biệt hợp tác với nhau (gồm các tiểu tác tử như Tác tử Trích xuất IOC, Tác tử Đối chiếu Playbook, Tác tử Soạn thảo Quy tắc Tường lửa và Tác tử Lập Báo cáo Pháp y) nhằm tối ưu hóa chất lượng lập luận. Hướng thứ hai là học liên hợp bảo vệ quyền riêng tư (Federated Learning), mở rộng kiến trúc sang mô hình phi tập trung, nơi nhiều nút SENTINEL phân tán có thể chia sẻ các trọng số mô hình hoặc dị biệt uy tín đã học được cục bộ mà không cần truyền tải các log thô nhạy cảm vi phạm quyền riêng tư. Hướng thứ ba là học tăng cường từ phản hồi của chuyên gia, tích hợp một vòng lặp học tăng cường cục bộ, trong đó tác tử cập nhật các tham số sinh quy tắc tường lửa dựa trên các hành động chấp thuận hoặc từ chối rõ ràng của chuyên viên SOC trong hàng đợi Streamlit HITL. Hướng thứ tư là tự thích ứng đối kháng (Adversarial Self-Hardening), triển khai một tác tử giả lập tấn công (Red Team Agent) chuyên biệt trong mạng container để tự động thăm dò SENTINEL bằng các cuộc

tấn công tiêm prompt và vượt rào, qua đó giúp hệ thống tự động kiểm thử và củng cố các token rào chắn của chính mình. Hướng thứ năm là định danh chiến dịch dựa trên TTP (TTP-based Campaign Attribution). Hệ thống hiện tại phát hiện *sự tồn tại* của một chiến dịch APT đa-ngày, đa-giai-đoạn theo cơ chế nổi lên (emergent), phi giám sát, thông qua đối chiếu tương quan đa-ngày trong Bộ nhớ Đe dọa, nhưng chủ ý KHÔNG gọi tên nhóm tấn công (intrusion set) cụ thể đứng sau. Một mở rộng tự nhiên là bổ sung một mô-đun sinh giả thuyết định danh nằm trên các định danh kỹ thuật có cấu trúc mà Lớp ánh xạ ATT&CK đã sản sinh: mỗi chuỗi kỹ thuật quan sát được theo từng nguồn sẽ được đối chiếu với hồ sơ kỹ thuật đã công bố của các Nhóm MITRE ATT&CK (ATT&CK Groups) bằng một độ đo tương đồng tập có trọng số, ví dụ Jaccard hoặc chồng lấp trọng số kiểu TF-IDF nhằm nâng trọng số cho các kỹ thuật hiếm, cho ra một danh sách các chiến dịch ứng viên được xếp hạng, mỗi ứng viên kèm một độ tin cậy tương đồng. Vì mở rộng này tái dùng chính đầu ra kỹ thuật có cấu trúc và chuỗi kill-chain theo từng nguồn vốn đã được duy trì trong Bộ nhớ Đe dọa, nó chủ yếu chỉ đòi hỏi việc nạp hồ sơ các Nhóm ATT&CK vào cơ sở tri thức. Tuy nhiên, điều cốt yếu là đầu ra này phải được trình bày nghiêm ngặt như một GIẢ THUYẾT được xếp hạng để điều tra viên xem xét, chứ không phải một phán quyết dứt khoát: định danh trong thực tế phụ thuộc vào tình báo vượt xa các thủ đoạn dùng chung, hạ tầng, thời điểm, dấu vết ngôn ngữ, bối cảnh địa chính trị, và khả năng luôn hiện hữu của việc cố ý giả mạo cờ hiệu (false-flag), và do các kỹ thuật thường được dùng chung giữa nhiều nhóm, một phép khớp thuần dựa trên TTP chỉ có thể là bằng chứng hỗ trợ, không bao giờ là bằng chứng khẳng định về tác giả.

Một hướng nữa là *trưởng thành hóa theo nhu cầu production* đối với hai năng lực nền tảng mà luận văn này mới kiểm chứng ở mức minh chứng khả thi: leo thang dị biệt không-chữ-ký và liên kết chiến dịch đa-ngày nổi lên, mà phạm vi cuối cùng của chúng tốt nhất được ấn định bởi chính môi trường doanh nghiệp cụ thể nơi SENTINEL được triển khai. Năng lực zero-day ở Tầng 1 hiện là điểm Z-score Welford đơn biến, theo từng feature, với ranh giới phát hiện được xác định ở mức $\approx 4\sigma$; một triển khai production được tinh chỉnh theo hồ sơ lưu lượng của từng tổ chức sẽ mở rộng nó sang các mô hình dị biệt đa biến hoặc học nhẹ và kiểm định trên các mẫu malware thật cùng telemetry đa dạng thay vì các proxy thống kê có kiểm soát được dùng ở đây. Đối xứng, liên kết APT đa-ngày hiện khóa theo IP nguồn, điều mà kẻ tấn công vô hiệu hóa bằng xoay IP, proxy hoặc botnet; bước tiến hóa tự nhiên, hỗ trợ cho mô-đun quy kết TTP ở trên, là khóa lại liên kết theo các kỹ thuật và thực thể ổn định để một chiến dịch vẫn liên kết được xuyên suốt hạ tầng thay đổi, và mở rộng đánh giá vượt ra ngoài kho ba-chiến-dịch báo cáo ở đây. Vì cả hai năng lực đã nằm sẵn trong pipeline đã triển khai (bộ lọc Welford ở Tầng 1 và Bộ nhớ Đe dọa bền vững ở Tầng 2), đây là các tinh chỉnh gia tăng do nhu cầu vận hành thực tế đòi hỏi chứ không phải hệ con mới.

Một hướng về phương pháp hỗ trợ cho việc củng cố này: đánh giá lại năng lực APT theo hướng khóa theo phán quyết và phân vùng theo thời gian. Như Chương 4 đã nói thẳng, thí

nghiệm APT hiện tại ghi một sự kiện vào Bộ nhớ Đe dọa theo chú thích ground-truth của DAPT2020, nên nó chỉ xác nhận logic liên kết đa ngày chứ không phải khả năng phát hiện đầu cuối của chính pipeline. Một đánh giá trung thực sẽ thay vào đó khóa việc ghi theo phán quyết thực của hai tầng, chỉ ghi những sự kiện mà Tầng 1 hoặc Tầng 2 thật sự gắn cờ, và phân vùng lưu lượng theo *thời gian bắt gói thật* thay vì ngẫu nhiên, bởi một phép chia ngẫu nhiên sẽ bịa ra chính cấu trúc đa ngày vốn định nghĩa một chiến dịch. Kho DAPT2020 vốn đã đa ngày một cách tự nhiên và CSE-CIC-IDS2018 cung cấp các bản bắt gói theo từng ngày, nên ranh giới ngày xác thực có sẵn mà không cần phân vùng nhân tạo. Mỗi ngày mô phỏng sẽ được độn thêm một nền benign quy mô production để tín hiệu chiến dịch phải sống sót qua nhiễu thực tế, với bộ lọc Tầng 1 $O(1)$ chạy ở toàn bộ khối lượng còn tầng mô hình ngôn ngữ chỉ được gọi trên tập escalate có giới hạn. Các chỉ số quan tâm khi đó sẽ trung thực và đầu cuối: recall APT thật khi các sự kiện tín hiệu thấp phải đi qua bộ lọc, tỷ lệ báo APT giả mỗi ngày mô phỏng, và tỷ lệ lọc benign của Tầng 1 ở quy mô lớn. Một đánh giá như vậy dự kiến sẽ báo một recall thấp hơn nhưng trung thực hơn, và phơi bày các báo APT giả từ những địa chỉ benign vô tình kích hoạt bộ lọc ở hai ngày khác nhau, qua đó cung cấp luận cứ thực nghiệm cho việc khóa lại liên kết theo kỹ thuật và thực thể thay vì theo IP nguồn, đúng như đã lập luận ở trên.

5.4.1 Lộ trình Mở rộng Quy mô theo Chiều ngang

Hướng thứ sáu mang tính xuyên suốt là khả năng mở rộng quy mô theo chiều ngang (Horizontal Scalability). Nguyên mẫu hiện tại được chủ ý triển khai trên một máy chủ đơn qua Docker Compose, nên thừa hưởng các nút thắt cổ chai của kiến trúc đơn nút mà hai giới hạn đã nêu ở trên, bão hòa hàng đợi đệ thường và năng lực tính toán trên một GPU duy nhất, làm bộc lộ rõ. Một bước tiến hóa lên môi trường sản xuất sẽ đi theo cảm nang kinh điển của hệ phân tán trên năm trục phối hợp, được lựa chọn sao cho giao ước nhận thức hai tầng cốt lõi vẫn giữ nguyên.

Trục thứ nhất là *phân mảnh (sharding) tầng lọc Tier-1 có trạng thái*. Tier-1 hiện lưu đường cơ sở Welford theo từng địa chỉ IP nguồn trong bộ nhớ của một tiến trình duy nhất, khiến nó trở thành một dịch vụ có trạng thái chưa thể mở rộng theo chiều ngang. Do trạng thái theo thời gian của mỗi IP nguồn độc lập với mọi IP khác, bộ lọc có thể được phân mảnh trên một cụm nhiều nút bằng cách áp dụng *băm nhất quán (consistent hashing)* lên khóa IP nguồn: mỗi IP được định tuyến một cách tất định tới đúng nút đang nắm giữ đường cơ sở của nó, nhờ đó bảo toàn nguyên vẹn đường cơ sở theo từng IP lần chuỗi sự kiện APT “chậm và ần ần”; năng lực lọc tăng tuyến tính theo số nút; và việc thêm hay bớt một nút chỉ tái cân bằng k/n khóa thay vì toàn bộ không gian khóa. Đây chính là bước biến thành phần có-trạng-thái duy nhất thành một tầng mở rộng được theo chiều ngang.

Trục thứ hai là *nhật ký thu nhận được phân mảnh và nhân bản*. Bộ môi giới Redis Streams

đơn dùng trong nguyên mẫu là một điểm lỗi đơn (single point of failure); nó sẽ được thay bằng một nhật ký cam kết (commit log) được phân mảnh và nhân bản (Redis Cluster hoặc Apache Kafka), với khóa phân mảnh được căn chỉnh trùng khóa sharding của Tier-1, để mọi sự kiện của một nguồn nhất quán đi tới đúng nút lọc đang sở hữu đường cơ sở của nguồn đó. Trục thứ ba là *tiêu thụ bất biến (idempotent)*: vì nhóm tiêu thụ (consumer group) hiện đã bảo đảm phân phát ít-nhất-một-lần (at-least-once), một lớp bất biến khóa theo một định danh sự kiện bất định sẽ được bổ sung, để việc phân phát lại sau sự cố không thể thực thi trùng lặp một hành động chặn.

Trục thứ tư là *cụm nhân công nhận thức co giãn (elastic worker pool)*. Thông lượng Tier-2 hiện bị chặn trần bởi một GPU duy nhất; nó sẽ được mở rộng thành một cụm các nhân công suy luận LLM phi trạng thái, cùng rút việc từ hàng đợi leo thang, với số lượng nhân công được tự động co giãn theo độ sâu hàng đợi quan sát được. Điều này trực tiếp giảm nhẹ giới hạn bão hòa hàng đợi (một đợt bùng nổ lưu lượng làm hàng đợi dài ra, và chính điều đó lại kích hoạt cấp phát thêm năng lực suy luận) trong khi Tier-1 bất định vẫn tiếp tục bảo vệ mạng một cách độc lập trong lúc suy luận bị dồn ứ. Trục thứ năm là *tăng lưu trữ bền vững được nhân bản*. Bộ nhớ Dede và kho audit SQLite sẽ được di trú sang một tầng dữ liệu chịu lỗi với mô hình nhất quán chọn theo từng loại tải: một kho khóa-giá-trị dựa trên đồng thuận số đông (thiết kế kiểu Dynamo hoặc Cassandra với ngưỡng $W + R > N$ tinh chỉnh được) phù hợp với tải uy tín IP và đối chiếu APT vốn dung thứ nhất quán cuối cùng (eventual consistency), trong khi chuỗi audit HMAC chống giả mạo và kho luật do con người phê duyệt vẫn giữ nhất quán mạnh trên một cơ sở dữ liệu quan hệ được nhân bản.

Đặt một bộ cân bằng tải trước tầng bảng điều khiển phi trạng thái và một bộ giới hạn tốc độ (rate limiter) phía thu nhận đứng trước bộ môi giới để hấp thụ các trận lũ lưu lượng sẽ hoàn thiện bức tranh. Gộp lại, năm trục này vạch ra một lộ trình di trú cụ thể từ một nguyên mẫu nghiên cứu đơn-máy đã được kiểm chứng sang một triển khai chịu lỗi, mở rộng được theo chiều ngang, giải quyết đúng các giới hạn bão hòa và một-GPU đã nêu ở trên, mà không làm thay đổi kiến trúc nhận thức hai tầng mà luận văn này đã xác thực.

Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu sắc trong hành trình bảo vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] A. L. Buczak and E. Guven, “A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [3] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [4] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [5] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019.
- [6] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [7] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [8] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [9] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [10] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [11] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.

- [12] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [13] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.
- [14] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [15] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [16] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [17] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [18] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [19] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [20] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [21] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [22] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [23] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [24] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [25] Gemma Team, Google, “Gemma 2: Improving Open Language Models at a Practical Size,” *arXiv preprint arXiv:2408.00118*, 2024.
- [26] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.

- [27] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [28] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
- [29] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [30] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [31] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [32] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [33] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [34] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [35] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.